



UNIVERSITÀ DI PISA

DIPARTIMENTO DI INFORMATICA

Corso di Laurea Triennale in Informatica

Progettazione e Analisi di Strategie Dinamiche di Intrusione attraverso il Security Twin

Relatori:

Fabrizio Baiardi
Vincenzo Sammartino

Candidato:

Francesco Lusini

ANNO ACCADEMICO 2025/2026

Voglio ringraziare anzitutto la mia famiglia che mi è stata accanto durante tutto il mio percorso, supportandomi ed aiutandomi nei momenti di difficoltà. Ringrazio Rosa per avermi sopportato anche nelle sessioni più dure, e soprattutto durante il lavoro per scrivere questa tesi. Ringrazio tutti gli amici che ho potuto incontrare durante questi anni di studio matto e disperato, con cui ho condiviso un numero tendente all'infinito di caffè alle macchinette e le chiacchiere durante le pause, che quasi sempre ci occupavano per pomeriggi. Ringrazio tutte le persone con cui ho vissuto negli spogliatoi e nei campi da pallavolo. Insieme abbiamo passato esperienze emozionanti che mi hanno permesso di non impazzire totalmente dietro allo studio e di sfogarmi quando ne ho avuto bisogno. Ringrazio anche tutti i compagni di terra e di mare che, seppur lontani, mi sono sempre stati vicini. Ringrazio per ultimi ma non certamente per importanza il professor Fabrizio Baiardi ed il suo prezioso collaboratore Vincenzo Sammartino per il loro supporto e per la loro disponibilità H24 e 7/7, che non mi hanno mai fatto mancare nonostante i problemi logistici.

Indice

Introduzione	1
1 Digital Twin del sistema target	3
2 Simulatore e strategie statiche di intrusione	7
2.1 Motore di simulazione	7
2.2 Strategie Statiche	9
2.2.1 NoisyGoalOriented	9
2.2.2 GreedyValue	10
2.2.3 Stealth	11
2.2.4 MaxProbability	12
3 Strategie Dinamiche	14
3.1 SwitchOnStall	14
3.2 SimulatedAnnealing	16
3.3 StochasticMaxProb	17
4 Risultati Sperimentali	19
4.1 Ambiente	19
4.2 Parametri	19
4.3 Metriche	20
4.4 Analisi delle Baseline	20
4.4.1 NoisyGoalOriented	21
4.4.2 GreedyValue	21
4.4.3 Stealth	21
4.4.4 MaxProbability	21
4.5 Analisi di SwitchOnStall	22
4.5.1 Studio del parametro k	23
4.5.2 Studio del parametro h	25
4.6 Analisi SimulatedAnnealing	30
4.7 Analisi StochasticMaxProb	32
5 Conclusioni	34

Appendice	37
I Risultati simulazioni di NOISYTOGREEDY	37
II Risultati simulazioni di NOISYTOMAXPROB	38
III Risultati simulazioni di GREEDYTOSTEALTH	39
IV Risultati simulazioni di STEALTHTOMAXPROB	40
V Risultati simulazioni di MAXPROBTOGREEDY	41
VI Risultati simulazioni di SIMUALTEDANNEALING	42
VII Risultati simulazioni di STOCHASTICMAXPROB	43
Bibliografia	44

Introduzione

La crescita e la complessità delle dimensioni delle infrastrutture basate sulle tecnologie di comunicazione ed informatiche ha reso sempre più inefficaci gli approcci tradizionali di difesa perimetrale dei sistemi. Le tecniche basate sugli inventari statici si rivelano inadeguate per mantenere il passo con la costante espansione del numero di connessioni ad una rete e con la sua complessità strutturale. Le tecniche maggiormente usate quali le scansioni attive, presentano dei limiti operativi all'interno dei sistemi. Per questo motivo è stato introdotto nell'ambito della sicurezza informatica il concetto di *Digital Twin*: una replica virtuale e dinamica della rete guidata dai dati raccolti dall'infrastruttura reale che consente di simulare attacchi informatici in un ambiente isolato e ben distinto da quello reale in maniera tale da valutare e predisporre le misure di difesa, senza però mettere a rischio il corretto funzionamento del sistema fisico. Uno dei metodi per testare la sicurezza di una rete è la simulazione di tentativi di intrusione utilizzando strategie statiche. Queste strategie seguono logiche decisionali rigide e non adattive rispetto al progredire dell'intrusione ed all'evoluzione del contesto rendendole non completamente aderenti alle situazioni reali.

Questo studio vuole analizzare questo aspetto operando su strategie di attacco progettate ed esaminate all'interno di un *Security Twin*, creato dal framework NOTLINE, di cui viene sfruttato anche il motore di simulazione basato sul metodo Monte Carlo. Per cercare di superare il limite che si è indicato sopra, e quindi per simulare intrusioni più aderenti a possibili scenari reali, si sono create delle combinazioni dinamiche di strategie statiche, ideate per modificare la propria logica decisionale alternando, ad esempio, modalità esplorative più prudenti a modalità più aggressive o determinate da componenti stocastiche, per poi analizzare e confrontare le prestazioni ottenute in termini di percentuale di successo, di rilevamento e di tempo medio simulato.

Questo elaborato è così organizzato. Il **Capitolo 1**, descrive le problematiche di partenza, il concetto di *Digital Twin* e l'architettura del framework NOTLINE, per poi passare, nel **Capitolo 2**, ad illustrare il funzionamento del motore di simulazione utilizzato e descrivere le quattro strategie di attacco statiche (NOISYGOALORIENTED, GREEDYVALUE, STEALTH, MAXPROBABILITY) dalle quali sono stati ricavati i dati che hanno costituito le baseline da utilizzare per i confronti. Il successivo **Capitolo 3** presenta le euristiche

dinamiche frutto della combinazione delle strategie statiche e che utilizzano, per il passaggio dall'una all'altra, differenti meccanismi di transizione quali lo stallo (`SWITCHONSTALL`), la temperatura (`SIMULATEDANNEALING`) o variabili stocastiche (`STOCHASTICMAXPROB`). I parametri e le modalità di simulazione sono state infine riportati, unitamente ai risultati di quest'ultime, nel **Capitolo 4** dove è indicato l'esito dei raffronti tra le varie soluzioni proposte e le baseline di partenza.

Il risultato ottenuto ha evidenziato come l'introduzione di fattori dinamici che determino, sulla base di diversi criteri, una deviazione del comportamento tipico delle strategie statiche si traduce in un miglioramento delle prestazioni generali e ciò si può notare in maniera più evidente nelle euristiche di base meno performanti che, a seguito dell'ibridazione, riescono a conseguire risultati in linea con le altre strategie.

Capitolo 1

Digital Twin del sistema target

A fronte di un ambiente informatico sempre più complesso ed esposto a minacce sempre nuove, una delle risposte che il mondo della sicurezza informatica ha fornito in questi ultimi tempi è stata l'introduzione del concetto di *Digital Twin* o Gemello Virtuale [1].

Un *Digital Twin* in termini di sicurezza informatica è la replica virtuale, dinamica e guidata dai dati (data driven) di un'infrastruttura reale. A differenza degli approcci utilizzati in passato, questa struttura si aggiorna in tempo reale ed è quindi in grado di riflettere velocemente i cambiamenti di stato, le configurazioni software e le topologie di comunicazione del sistema fisico. Questo paradigma permette quindi di analizzare prestazioni e altri parametri della rete, testare l'impatto di nuove configurazioni, e soprattutto andare ad eseguire delle simulazioni di attacchi informatici in un ambiente sicuro, senza alcun rischio di interruzione e carico di lavoro per i sistemi in produzione.

La costruzione di un *Digital Twin* richiede una visibilità profonda e continua sugli asset di rete. Questo processo è stato storicamente svolto da tecniche di Active Scanning [2], che producono informazioni dettagliate sugli asset attraverso interazioni dirette, ma che presentano una limitazione importante, cioè la generazione di traffico di rete, che può indurre i sistemi di rilevamento a considerarlo come possibile minaccia attiva, portando quindi alla conseguente interruzione del processo di mappatura. Oltre a questa possibile eventualità, un altro aspetto da considerare è l'impatto sugli ambienti sensibili delle tecnologie operative, dove le attività di scansione potrebbero ridurre sia la larghezza di banda che quella computazionale nei sistemi di controllo industriale per esempio, causando quindi dei possibili tempi di inattività del processo di produzione [3].

Un altro approccio usato, diverso dall'Active Scanning per la creazione di un *Digital Twin*, prevede l'uso della scoperta passiva della rete, senza quindi

l'utilizzo di pacchetti aggiuntivi. Nonostante la maggiore discrezione, e la minore invadenza, queste metodologie hanno delle limitazioni importanti, potendo in alcuni casi creare delle mappe incomplete delle reti. Questa visibilità incompleta è spesso causata da una possibile mancata rilevazione dei dispositivi prolungatamente inattivi, o dal volume di traffico molto ridotto, che compromette il modello digitale, andando a creare un gap tra quest'ultimo e il suo corrispettivo fisico [4].

Per cercare di trovare un giusto compromesso tra le prestazioni dello scanning attivo e la non-invasività dello scanning passivo, è stata creata la piattaforma NOTLINE [5], sulla quale si basa questo lavoro di tesi, un framework innovativo progettato per la generazione automatica di *Digital Twin* attraverso un approccio non intrusivo. Il sistema target analizzato in questo studio, infatti, è stato ricavato proprio utilizzando l'ecosistema di NOTLINE e sempre da questa piattaforma sono stati presi il motore di attack-simulation e le strategie baseline.

Il paradigma alla base della piattaforma si fonda sulla raccolta passiva e continua dei metadati del traffico di rete multiprotocollo: invece di interrogare attivamente gli host, NOTLINE intercetta in modo trasparente le comunicazioni legittime già presenti nell'infrastruttura.

La prima fase della costruzione del *Digital Twin* è quindi l'utilizzo di strumenti di monitoraggio come nTop [6] per raccogliere un flusso ininterrotto di metadati dal monitoraggio passivo di protocolli come ARP, SSDP, ICMP ed altri, che costituisce la base su cui andare a formare il gemello. Fatto ciò questi metadati vengono filtrati per rimuovere duplicati e rumori considerati irrilevanti; una volta finito, un meccanismo di correlazione connette gli indirizzi IP agli indirizzi MAC attraverso ARP e grazie a sofisticati strumenti prepara questi dati per essere raccolti in un insieme coeso di eventi pronti per la modellazione del grafo della topologia della rete [7].

Per rendere ancora più efficace il modello generato dai dati raccolti, NOTLINE introduce un meccanismo automatizzato di vulnerability mapping. Questa procedura si avvale di repository istituzionali di threat intelligence per incrociare ogni nodo software con il database delle *Common Vulnerabilities and Exposure* (CVE) note e storicizzate. Questi database vengono aggiornati periodicamente per poter tener conto di vulnerabilità anche recenti, ed aumentare quindi l'efficacia della procedura. Durante l'arricchimento vengono aggiunte metriche standardizzate, come la valutazione basata sul framework CVSS (Common Vulnerability Scoring Sistem), che permette al *Digital Twin* di essere utilizzato anche come strumento per quantificare il rischio. Questa integrazione consente quindi di unire l'inventario appena creato alle minacce reali, fornendo delle metriche matematiche di successo che un potenziale attaccante riscontrerebbe nella compromissione di uno specifico nodo.

L'efficacia del processo di arricchimento delle vulnerabilità e della creazione del grafo sono legate all'aggiornamento in tempo reale di NOTLINE. Come si

è già accennato, a differenza degli approcci di assessment tradizionali, che si affidano a scansioni periodiche o a polling manuali, l'infrastruttura opera in un regime di Continuous Collection [1]. I sensori passivi rimangono costantemente in ascolto sui flussi multiprotocollo, garantendo l'intercettazione di cosiddetti Short-lived Device o di trasmissioni di servizi effimeri, che sfuggirebbero a scansioni periodiche. Questa continua acquisizione di informazioni crea anche un meccanismo di Continuous Update, grazie al quale NOTLINE è in grado di scoprire nuovi nodi o di eliminare nodi che sono stati inattivi per un certo periodo di tempo. Tutto questo modifica e aggiorna la conformazione del grafo, consentendogli di rispecchiare in qualunque momento il suo corrispettivo fisico, anche quando un nuovo nodo interagisce con uno esistente. Questa caratteristica di sincronizzazione non si limita ai singoli nodi però, ma si estende anche al livello di vulnerabilità: la scoperta e la pubblicazione di nuove vulnerabilità (CVE) che riguardano software già censiti comporta un ricalcolo automatico e immediato dei valori calcolati per determinare il rischio del grafo.

Monitorando costantemente i metadati, NOTLINE è in grado di modellare una baseline del traffico legittimo della rete. Qualsiasi deviazione significativa da questo standard, come picchi anomali di traffico ICMP, un ricambio insolito nelle assegnazioni DHCP o variazioni inattese nei gruppi Multicast, viene immediatamente intercettata. Queste deviazioni generano degli alert e tag semantici associati ai nodi del *Digital Twin*, contrassegnando gli eventi sospetti per evidenziarli per ulteriori ispezioni più approfondite.

Parallelamente a questo monitoraggio in tempo reale di anomalie, NOTLINE affianca anche un processo di Periodic Assessment (valutazione periodica del rischio). Ad intervalli temporali predefiniti infatti ricalcola le assegnazioni delle vulnerabilità, riconvalida la conformità della configurazione ed esegue nuovamente, grazie ad un motore di simulazione, delle simulazioni di attacco, tenendo conto delle ultime vulnerabilità scoperte. Questo ciclo periodico di valutazioni e di aggiornamento è dettato più dalle inferenze tratte dalla valutazione del rischio offline che da cambiamenti nel sistema descritto dal gemello, garantendo sempre il valore più alto di predittività.

Oltre alle operazioni di monitoraggio continuo e di assessment periodico, un altro elemento della piattaforma NOTLINE, è la modularità. Il sistema è progettato infatti per integrare motori di analisi avanzata, in grado di recepire ulteriori informazioni contestuali, come l'adozione di specifici modelli di minaccia (Threat Models). L'utilizzo di questi moduli all'interno della piattaforma consente quindi non solo di creare inventari precisi del proprio sistema digitale, ma anche di utilizzarli come ambiente di sperimentazione attiva sicuro, e di diventare quindi uno strumento prezioso nelle mani degli esperti di sicurezza informatica.

Tra i vari moduli è ovviamente determinante il motore di simulazione: sfruttando la composizione della rete corrente e le associazioni di vulnerabilità

calcolate in precedenza, il motore esegue simulazioni di intrusioni adottando un metodo *Monte Carlo* [8] simulazioni ripetute. Questo processo permette di identificare i percorsi ad alto rischio: dati importanti composti dai percorsi che interconnettono i nodi all'interno della rete, e che potrebbero essere utilizzati come percorsi ottimali durante una ipotetica intrusione informatica. L'utilizzo di questo motore, e soprattutto dei risultati da esso prodotti, ne consente l'utilizzo per il successivo calcolo delle probabilità di successo dei vari attaccanti e definire le priorità delle strategie di mitigazione, così da prevenire effettive future intrusioni.

E' proprio su questo motore di simulazione e sull'analisi dei loro risultati che si basa il lavoro di questa tesi. Nello specifico, l'ambiente di simulazione ha permesso di valutare inizialmente l'efficacia e i limiti strutturali di strategie di attacco statiche, considerate poi come baseline [9]. Successivamente, sulla base delle metriche raccolte, queste stesse sono state usate per analizzare nuove strategie dalle caratteristiche ibride, permettendo un confronto oggettivo e quantitativo delle prestazioni e consentendo di raccogliere, studiare ed analizzare metriche importanti come le percentuali di successo, fallimento e rilevamento dei diversi approcci all'interno del *Digital Twin* di un sistema target.

Capitolo 2

Simulatore e strategie statiche di intrusione

2.1 Motore di simulazione

Il nucleo analitico del lavoro si fonda su un motore di simulazione progettato per operare sul *Digital Twin* generato dalla piattaforma NOTLINE. L'obiettivo primario di questo componente non è la riproduzione fedele dei pacchetti di rete a basso livello, bensì l'emulazione delle logiche decisionali e delle transizioni di stato che caratterizzano un'intrusione informatica. L'architettura del simulatore adotta un approccio statistico basato sul metodo Monte Carlo, necessario per gestire l'intrinseca incertezza derivante dalle probabilità di successo delle vulnerabilità (CVE) e dalle possibili reazioni dei sistemi di difesa.

Il funzionamento del motore può essere descritto attraverso un flusso logico sequenziale che si astrae dalla complessità implementativa. In una fase preliminare, il sistema carica la topologia del grafo, le associazioni di vulnerabilità e i parametri della strategia di intrusione selezionata. Una volta inizializzato l'ambiente, viene avviato un ciclo di iterazioni multiple, dove ogni iterazione simula un tentativo di intrusione indipendente. In ogni singola simulazione, l'agente attaccante valuta, passo dopo passo, i nodi adiacenti accessibili e seleziona l'azione da intraprendere. Questa selezione non è casuale, ma guidata da una logica decisionale, o strategia, che può variare da un approccio puramente stocastico a uno guidato da euristiche di massimizzazione del privilegio.

L'esecuzione di ogni azione comporta un confronto probabilistico. Il motore calcola l'esito basandosi sui punteggi *CVSS* e sulle metriche di rischio associate al nodo bersaglio. In caso di successo, l'attaccante espande la propria superficie di controllo, acquisendo nuovi privilegi e visibilità su ulteriori porzioni del grafo. Viceversa, un fallimento non si limita a impedire l'avanzamento, ma contribuisce all'incremento di un contatore di "rumore", che determina la probabilità che le attività malevole vengano intercettate dai sistemi

di monitoraggio difensivo. La simulazione della singola catena di intrusione prosegue finché non si verifica una condizione di arresto, determinata dal raggiungimento dell'obiettivo critico (compromissione del target), dall'avvenuto rilevamento dell'intrusione o dall'esaurimento delle risorse temporali a disposizione.

Di seguito è riportata la formalizzazione ad alto livello dell'algoritmo implementato, che evidenzia la struttura dei cicli decisionali e la gestione degli stati di transizione, senza scendere nei dettagli sintattici del linguaggio di programmazione utilizzato.

Algoritmo 1: Logica del motore di simulazione Monte Carlo

Input: Grafo della rete G , Insieme delle Vulnerabilità V , Numero di run N

Output: Metriche di successo e rilevamento

```

1  Inizializza le strutture dati per la raccolta statistica;
2  for  $i \leftarrow 1$  a  $N$  do
3      Carica lo stato iniziale del grafo  $G$ ;
4      Posiziona l'attaccante al nodo di ingresso (Entry Point);
5      Imposta  $Rilevato \leftarrow Falso$ ;
6      Imposta  $ObiettivoRaggiunto \leftarrow Falso$ ;
7      while  $(\neg Rilevato)$  and  $(\neg ObiettivoRaggiunto)$  do
8          Identifica l'insieme  $A$  delle azioni possibili dai nodi controllati;
9          if  $A$  non è vuoto then
10             // Selezione basata sulla strategia (es. Random o Greedy)
11              $azione \leftarrow \text{SelezionaAzione}(A, strategia)$ ;
12              $esito \leftarrow \text{EseguiAzione}(azione, V)$ ;
13             if  $esito = SUCCESSO$  then
14                 Aggiorna i nodi controllati e i privilegi;
15                 if Target finale compromesso then
16                      $ObiettivoRaggiunto \leftarrow Vero$ ;
17                 end
18             end
19             else // Gestione fallimento
20                 Incrementa livello di allerta;
21                 if Livello allerta  $>$  Soglia rilevamento then
22                      $Rilevato \leftarrow Vero$ ;
23                 end
24             end
25             // Nessuna azione possibile, stallo
26             Interrompi ciclo corrente (Deadlock);
27         end
28     Salva i risultati dell'iterazione  $i$ ;
29 end
30 Elabora le statistiche aggregate finali;

```

2.2 Strategie Statiche

L'efficacia del motore appena descritto è strettamente correlata alla logica di selezione delle azioni, definita come "strategia". In una prima fase di analisi sono state implementate e testate quattro strategie di natura statica. Queste rappresentano comportamenti in cui l'attaccante non adatta il proprio *modus operandi* in base alla storia pregressa o all'apprendimento, ma segue regole deterministiche o puramente casuali.

2.2.1 NoisyGoalOriented

La prima euristica, che possiamo indicare come strategia NOISYGOALORIENTED, modella un attaccante privo di conoscenza pregressa sulla conformazione della sistema target il cui unico obiettivo è la compromissione di nodi ad alto valore strategico. Il comportamento di questa strategia è intrinsecamente caotico ed affatto cauto: il modello introduce infatti un fattore di penalità di rumore molto alto per ogni singola azione compiuta.

La logica di scelta della mossa da eseguire è prevalentemente probabilistica: la strategia tenta di innalzare i propri privilegi o di estrarre credenziali solamente quando si trova in condizioni di sistema specifiche, come per esempio quando opera con diritti limitati o su macchine ad alta importanza; in tutti gli altri casi la strategia sceglie quali azioni compiere tra quelle possibili ricorrendo ad un meccanismo stocastico pesato e privilegiando l'esplorazione dei nodi vicini.

La tipologia di esplorazione favorita è un'esplorazione laterale, guidata anch'essa da uno specifico meccanismo stocastico basato sui valori dei nodi.

A causa della sua notevole penalizzazione determinata dal rumore generato, anche i tentativi di compromissione più semplici rischiano di innescare rapidamente le difese della rete, e ciò rende questo profilo altamente suscettibile di rilevazione.

Algoritmo 2: Logica decisionale: NOISYGOALORIENTED

Input: Stato corrente dell'intrusione S , Nodo Corrente, Nodi Adiacenti**Output:** Azione selezionata, relativo Bersaglio

```

// Selezione dell'Azione
1 if (Privilegi sul Nodo Corrente == Utente) AND (Probabilità < 0.9) then
2   | Azione  $\leftarrow$  Acquisizione Privilegi;
3 else if Valore strategico Nodo Corrente  $\geq$  500 then
4   | Azione  $\leftarrow$  Estrazione Credenziali;
5 else
6   | // Scelta stocastica in assenza di condizioni critiche
7   | Azione  $\leftarrow$  Estrazione Casuale Pesata (Movimento Laterale: 70%, Estrazione
8   | Credenziali: 20%, Escalation: 10%);
9   |
// Selezione del Target
7 if Azione == Movimento Laterale then
8   | Assegna a ogni nodo adiacente un peso proporzionale al suo Valore Strategico;
9   | Bersaglio  $\leftarrow$  Selezione Casuale Pesata(Nodi Adiacenti, Pesi);
10 return Azione, Bersaglio;

```

2.2.2 GreedyValue

Il secondo approccio logico è quello della Strategia GREEDYVALUE che, meno rumorosa della precedente, emula un attaccante che orienta le proprie decisioni esclusivamente attraverso la massimizzazione dei valori dei sistemi compromessi, puntando direttamente ai nodi più importanti della rete, ignorando deliberatamente eventuali rischi di intercettazione.

L'albero decisionale in questo caso è deterministico e strettamente sequenziale, variando unicamente in funzione dello stato di compromissione del nodo controllato. La strategia esegue in maniera sistematica l'escalation dei privilegi non appena riesce a violare un nodo; successivamente valuta la necessità di estrarre i token di autenticazione, dando priorità ai bersagli con valore strategico più alto per i quali non possiede ancora le credenziali di amministratore globale o locale.

Esaurita la fase di acquisizione di dati sul nodo, l'euristica effettua un movimento laterale diretto verso nuovi nodi, che vengono individuati scegliendo, tra quelli adiacenti, quello con il valore più alto.

Algoritmo 3: Logica decisionale: GREEDYVALUE

Input: Stato corrente dell'intrusione S , Nodo Corrente, Nodi Adiacenti
Output: Azione selezionata, relativo Bersaglio

```

// Selezione dell'Azione (Esecuzione Sequenziale)
1 if Privilegi sul Nodo Corrente == Utente then
2   | Azione  $\leftarrow$  Escalation dei Privilegi;
3 else if Privilegi == Amministratore then
4   | if  $\neg(\text{CredenzialiDominio})$  AND (Valore Nodo Corrente è Massimo) then
5     | Azione  $\leftarrow$  Estrazione Credenziali;
6   | else if  $\neg(\text{CredenzialiLocali})$  then
7     | Azione  $\leftarrow$  Estrazione Credenziali;
8   | else
9     | // Finite le azioni da compiere sul nodo si passa al prossimo
      | target
      | Azione  $\leftarrow$  Movimento Laterale;

// Selezione del Target
10 if Azione == Movimento Laterale then
11   | Bersaglio  $\leftarrow$  Nodo Adiacente con il massimo Valore Strategico;
12 return Azione, Bersaglio;
```

2.2.3 Stealth

Rispetto all'aggressività ed alla rumorosità dei primi due approcci, la strategia STEALTH modella un'attaccante il cui obiettivo è minimizzare l'impronta di rilevamento, al fine di non destare sospetti e massimizzare di conseguenza la probabilità di persistere nel sistema. La caratteristica fondamentale di questa strategia è l'introduzione di un parametro logico di tolleranza del rumore generato. Per la scelta dell'azione da compiere viene preventivamente verificato il rumore generato con le mosse precedenti: qualora il livello superi la soglia di allerta preimpostata, si esegue un'attesa prolungata così da far decadere il valore del rumore e di conseguenza l'allerta del sistema. Per quanto concerne l'avanzamento topologico, l'approccio è estremamente cauto: l'attaccante sfrutta le credenziali acquisite per compromettere più nodi possibile ricorrendo ad operazioni più rumorose di acquisizione dei privilegi solo se strettamente necessario. Nella scelta del bersaglio questa strategia agisce in maniera opposta rispetto alla strategia GREEDY: predilige infatti i nodi adiacenti con un il valore strategico minimo, garantendosi un percorso di intrusione statisticamente più sicuro, seppur a costo di un sensibile allungamento della catena di compromissioni necessaria per raggiungere l'obiettivo primario.

Algoritmo 4: Logica decisionale: STEALTH

Input: Stato corrente dell'intrusione S , Soglia Tolleranza Rumore, Nodo Corrente, Nodi Adiacenti
Output: Azione selezionata

```

// Selezione dell'Azione
1 if Rumore Attuale > Soglia Tolleranza then
2   | return Attesa (per velocizzare il decadimento del rumore);

3 if Attaccante possiede Credenziali di Amministrazione (Locali o di Dominio) then
4   | // Sfrutta le credenziali per muoversi silenziosamente senza exploit
5   | Azione  $\leftarrow$  Movimento Laterale;
6 else if Privilegi sul Nodo Corrente == Utente then
7   | Azione  $\leftarrow$  Escalation dei Privilegi;
8 else
9   | Azione  $\leftarrow$  Estrazione Credenziali;

// Selezione del Target
9 if Azione == Movimento Laterale then
10  | Bersaglio  $\leftarrow$  Nodo Adiacente con il minimo Valore Strategico;
11 return Azione, Bersaglio;

```

2.2.4 MaxProbability

L'ultimo profilo analizzato, nonché l'euristica più performante tra quelle proposte, è la strategia basata sulla Massimizzazione della Probabilità (MAXPROBABILITY).

Questa implementazione delinea uno stile di attacco basato sull'ottimizzazione statistica del tasso di successo di ogni singolo attacco.

Da un punto di vista procedurale e della scelta della mossa successiva, la logica di acquisizione di privilegi e credenziali ricalca l'impostazione sequenziale deterministica della strategia GREEDY, culminando nel movimento laterale una volta esaurite le azioni da compiere sul nodo compromesso. La differenza sostanziale risiede nel criterio di scelta del target: una funzione decisionale specifica valuta le metriche di vulnerabilità *CVSS* di tutti i nodi adiacenti e seleziona come obiettivo successivo quello caratterizzato dal punteggio di gravità più elevato.

Questo criterio, il cui impatto sui risultati sarà affrontato più oltre, si allinea perfettamente con il modello stocastico del simulatore, in cui la probabilità di successo di un attacco è direttamente correlata alla criticità della vulnerabilità sfruttata, in combinazione con la skill dell'attaccante. Esplorando il grafo attraverso i nodi statisticamente più compromettibili, questa strategia ottimizza il successo delle varie operazioni, abbattendo drasticamente sia i tempi di esecuzione sia l'accumulo del rumore derivato da tentativi falliti.

Algoritmo 5: Selezione del bersaglio: MAXPROBABILITY

Input: Grafo della Rete, Nodi Adiacenti Accessibili**Output:** Nodo bersaglio ottimale

```
1 Inizializza Valore Massimo CVSS  $\leftarrow$  0;
2 Inizializza Bersaglio Ottimale  $\leftarrow$  Vuoto;
  // Valutazione della vulnerabilità dei nodi per la scelta del target
3 foreach Nodo in Nodi Adiacenti do
4   Vulnerabilità Maggiore  $\leftarrow$  Estrai punteggio CVSS più alto tra i software del
   Nodo;
5   if Vulnerabilità Maggiore > Valore Massimo CVSS then
6     Valore Massimo CVSS  $\leftarrow$  Vulnerabilità Maggiore;
7     Bersaglio ottimale  $\leftarrow$  Nodo;
8 return Bersaglio ottimale;
```

L'esame del comportamento di queste strategie statiche ha fornito i dati che, assunti come baseline, sono stati utilizzati, nelle sezioni successive, per valutare l'impatto di approcci ibridi e più evoluti.

Capitolo 3

Strategie Dinamiche

L'analisi condotta sulle euristiche di base ha evidenziato nella maggior parte dei casi un problema strutturale intrinseco a tutti i profili analizzati: la rigidità decisionale. Operando secondo paradigmi non modificabili, le strategie si rivelano incapaci di adattare le proprie scelte al contesto ed all'evoluzione dell'intrusione. È proprio prendendo le mosse da questa limitazione che sono stati formalizzati approcci dinamici, concepiti per modificare le logiche decisionali a tempo di esecuzione in risposta a determinati fattori ambientali. Questo lavoro si è approcciato al problema utilizzando delle procedure della baseline in combinazione tra loro in modalità ibrida per sperimentare e testare l'andamento delle simulazioni al variare di un criterio di scambio da una configurazione all'altra.

3.1 SwitchOnStall

Una prima combinazione dinamica fonde i paradigmi decisionali di due strategie baseline, scegliendo l'approccio da utilizzare mediante il ricorso ad un valore di progresso dell'intrusione determinato dall'acquisizione di nuovi nodi e dall'estrazione di nuove credenziali: al raggiungimento di un valore prestabilito di mancato progresso seguirà la scelta di un diverso approccio. L'analisi di questa strategia è stata articolata in due fasi distinte in cui sono stati studiati gli effetti dell'introduzione, anzitutto, del parametro k con l'individuazione di una soglia “di stallo” ed in seguito del parametro h per il ritorno alla strategia di partenza.

Il parametro k individua il numero di iterazioni senza progresso ammesse (soglia di stallo) prima di passare ad un diverso approccio euristico secondario. Il parametro h individua il numero di iterazioni compiute dalla strategia secondaria prima di tornare ad utilizzare quella primaria. In una prima fase, incentrata sullo studio del parametro k , il motore viene inizializzato con un comportamento primario e uno secondario, presi dalle baseline presenti. Il sistema quindi tiene traccia delle iterazioni improduttive: qualora l'agente

non registri alcun avanzamento per un numero di azioni pari alla soglia di k impostata, viene diagnosticata una condizione di stallo. Per cercare di uscire da tale situazione, l'attaccante cambia la strategia decisionale, passando da quella primaria a quella secondaria: questo crea situazioni uniche in cui, ad esempio, un approccio conservativo e prudente si evolve e si trasforma in uno più aggressivo, in modo da uscire da una situazione di stallo e proseguire l'intrusione.

Algoritmo 6: Logica decisionale: SWITCHONSTALL_K

Input: Stato corrente dell'intrusione S , Strategia Primaria A , Strategia di Riserva B , Soglia di stallo k
Output: Azione selezionata

```

// Inizializzazione dello stato interno della strategia
1 if Variabili di strategia non inizializzate then
2   Imposta Strategia Attiva  $\leftarrow A$ ;
3   Contatore Stallo  $\leftarrow 0$ ;
4   Progresso Precedente  $\leftarrow \text{CalcolaProgresso}(S)$ ;

// Valutazione del progresso
5 Progresso Attuale  $\leftarrow \text{CalcolaProgresso}(S)$ ;

// Verifica necessità Aggiornamento strategia in uso
6 if Strategia Attiva ==  $A$  then
7   if Progresso Attuale > Progresso Precedente then
8     // L'attacco sta producendo risultati utili, si azzeri il
      contatore
9     Contatore Stallo  $\leftarrow 0$ ;
10    Progresso Precedente  $\leftarrow$  Progresso Attuale;
11  else
12    // L'attacco non produce risultati, si incrementa lo stallo
13    Contatore Stallo  $\leftarrow$  Contatore Stallo +1;

    // Verifica della condizione di transizione
14  if Contatore Stallo  $\geq k$  then
15    Imposta Strategia Attiva  $\leftarrow B$ ;
16    // Passaggio  $A \rightarrow B$ 

// Delega della decisione all'euristica correntemente in uso
17 Azione  $\leftarrow \text{ScegliProssimaAzione}(\text{Strategia Attiva}, S)$ ;
18 return Azione;
```

La seconda fase di questa prima strategia introduce un ulteriore grado di dinamicità mediante il parametro di durata h . In questa configurazione, la transizione verso l'euristica secondaria non è definitiva ma è solamente temporanea. In altri termini, al verificarsi di uno stallo, l'agente adotta la strategia secondaria per un numero strettamente limitato e predeterminato di iterazioni; esaurita questa finestra operativa, a prescindere dall'esito conseguito, il sistema ripristina l'euristica primaria.

3.2 Simulated Annealing

Per aumentare ancora di più il livello di dinamicità si è considerata una ulteriore strategia ispirata ad un paradigma ampiamente consolidato nel campo dell'ottimizzazione combinatoria e del machine learning: il *Simulated Annealing* [10].

In questa ricerca il paradigma del Simulated Annealing è stato riadattato per coordinare l'alternanza tra euristiche, sempre tratte dalle baseline, più furtive ed euristiche caratterizzate da una rilevante aggressività esplorativa.

Il sistema assume come strategia primaria di attacco la strategia di base Stealth, mirata ad esplorare il grafo mantenendo il livello di rumore generato al di sotto delle soglie di rilevamento e prediligendo percorsi a basso rischio di intercettazione.

Per superare le limitazioni legate ad un approccio estremamente (troppo) prudente, viene introdotto un parametro di temperatura che, entro un range predefinito, varia in maniera inversamente proporzionale alla progressione verso il goal. Al raggiungimento di valori termici elevati (alto numero di insuccessi), la strategia ha un'alta probabilità di eseguire una sequenza secondaria di passi guidati dall'euristica della strategia probabilistica (MAXPROB). La sequenza viene seguita per un numero predeterminato di iterazioni, terminate le quali la strategia torna all'euristica primaria ed inizia un processo di raffreddamento del parametro temperatura.

Tale approccio cerca di superare i limiti della scarsa incisività nell'esplorazione della strategia STEALTH, troppo prudente, combinando tale prudenza finalizzata al mantenimento di un basso livello di rumore con dei momenti, opportunamente calcolati, di esplosività indirizzati secondo un approccio probabilistico.

Algoritmo 7: Logica decisionale: SIMULATEDANNEALING

Input: Stato corrente S , Temperatura Iniziale T_0 , Incremento ΔT , Fattore Raffreddamento γ , Funzione $p(T)$, Lunghezza Max Deviazione L

Output: Azione selezionata, relativo Bersaglio

```

// Inizializzazione dello stato termico
// Gestione deviazione in corso
1 if Passi Devianti Rimanenti > 0 then
2   Passi Devianti Rimanenti  $\leftarrow$  Passi Devianti Rimanenti  $-1$ ;
3   Modalità Corrente  $\leftarrow$  MaxProb;
4   if Passi Devianti Rimanenti == 0 then
5     // Raffreddamento del sistema al termine della deviazione
6     Temperatura Corrente  $T \leftarrow T \times \gamma$ ;
7   return Azioni e bersaglio scelti da MaxProb;

// 3. Aggiornamento Termico
8 if Obiettivo primario non ancora raggiunto then
9   Temperatura Corrente  $T \leftarrow T + \Delta T$ 
10 else
11   Temperatura Corrente  $T \leftarrow \max(0, T - 2\Delta T)$ 

// Calcolo della probabilità di una deviazione
12 Probabilità di Deviazione  $p \leftarrow$  CalcolaFunzione(Temperatura Corrente  $T$ ) Genera
    numero casuale  $r \in [0, 1)$ ;
13 if  $r < p$  then
14   Lunghezza deviazione  $\leftarrow$  Estrazione casuale intera in  $[1, L]$ ;
15   Passi Devianti Rimanenti  $\leftarrow$  Lunghezza deviazione  $-1$ ;
16   Modalità Corrente  $\leftarrow$  MaxProb;
17   if Passi Devianti Rimanenti == 0 then
18     // Se la deviazione è di un solo passo, raffredda
19     immediatamente
20     Temperatura Corrente  $T \leftarrow T \times \gamma$ ;
21   return Azioni e bersaglio scelti da MaxProb;
22 else
23   // Nessuna deviazione, quindi viene utilizzata la strategia
24   primaria
25   Modalità Corrente  $\leftarrow$  Stealth;
26   return Azioni e bersaglio scelti da Stealth;

```

3.3 StochasticMaxProb

L'ultima strategia dinamica analizzata mira a mitigare il problema della prevedibilità statistica dell'attaccante attraverso l'inserimento intenzionale e controllato di rumore decisionale, introducendo un ibrido stocastico. Le euristiche incentrate unicamente sull'efficienza, come la baseline basata sulla Probabilità, infatti generano percorsi di attacco che possono rivelarsi ripetitivi pro-

ducendo dei pattern comportamentali evidenti, che rendono la strategia più facilmente soggetta a rilevamento.

Questa strategia stocastica mantiene come base la strategia MAXPROBABILITY, tuttavia, prima di eseguire l'azione ottimale calcolata, il motore introduce una componente aleatoria. Sulla base di una probabilità marginale prestabilita, l'agente devia intenzionalmente dalla logica primaria. L'azione divergente, che viene indicata e manipolata con un parametro p , può essere scelta da strategie stealth o risultare puramente casuale. La perturbazione agisce alla stregua di un micro-difetto strutturale introdotto deliberatamente nell'albero decisionale: sacrificando una frazione ridotta dell'efficienza teorica, l'agente frammenta e confonde la propria impronta operativa, riducendo drasticamente le probabilità di essere profilato ed incrementando, nel medio-lungo termine, le proprie capacità di elusione dei sistemi di rilevamento.

Algoritmo 8: Logica decisionale: Strategia a Perturbazione Stocastica

Input: Stato corrente S , Probabilità di Perturbazione p , Modalità di Deviazione M

Output: Azione selezionata, relativo Bersaglio

```

// Selezione dell'Azione
1 Genera un valore casuale  $r \in [0, 1)$ ;
2 if  $r < p$  then
    // Innesco della deviazione
3     if  $M == \text{Furtiva (Stealth)}$  then
4         Azione  $\leftarrow$  Delega a Strategia Stealth;
5     else if  $M == \text{Casuale}$  then
6         Azione  $\leftarrow$  Estrazione Casuale Uniforme (Escalation, Estrazione,
            Movimento, Attesa);
7 else
    // Nessuna deviazione
8     Azione  $\leftarrow$  Delega a Strategia MaxProb;

// Selezione del Bersaglio Standard
9 Bersaglio  $\leftarrow$  Delega a Strategia MaxProb
10 return Azione, Bersaglio;

```

Capitolo 4

Risultati Sperimentali

Utilizzando il motore di simulazione implementato in NOTLINE sono stati ricavati i dati per la valutazione delle singole euristiche, partendo da quelle statiche per passare poi a quelle dinamiche, che hanno consentito le analisi alla base di questo lavoro e le conclusioni a cui è giunto.

4.1 Ambiente

Il test è stato effettuato all'interno di un sistema digitale (*Security Twin*) costruito all'interno del framework NOTLINE. Il processo di scoperta nel simulatore ha identificato e mappato 111 host distribuiti in 25 sottoreti distinte. Successivamente alla ricostruzione topologica della rete, il sistema ha effettuato l'analisi di 1763 software unici e, interrogando il database NVD, ha mappato le relative vulnerabilità calcolando così i punteggi di gravità *CVSS* ed assegnandoli ai singoli nodi.

4.2 Parametri

Definito l'ambiente della simulazione, si è passati ai parametri di funzionamento del motore: livello di casualità del modello (caratteristica del metodo Monte Carlo), abilità dell'attaccante (*skill*) ed l'efficacia delle misure di sicurezza (*detection rate*).

Nel metodo Monte Carlo l'affidabilità delle stime statistiche è strettamente connessa ad un fattore di casualità correlato al numero di ripetizioni dei test. Nello specifico, quindi, la valutazione di ogni strategia ha previsto l'esecuzione di almeno 100 campagne di simulazioni.

Ogni campagna prevede l'esecuzione di singole istanze di intrusione sino al raggiungimento di un limite massimo – impostato in questa fase a 200.000 – o, in alternativa, qualora non rilevi ulteriori percorsi di attacco unici e quindi raggiunga la stabilità statistica.

Altri due parametri sono necessari al simulatore per la configurazione dell'ambiente. Il primo (skill) indica e valorizza l'abilità dell'attaccante nel compromettere l'host; in queste simulazioni il valore è stato impostato 0,9 che corrisponde ad livello elevato così da facilitare il compito degli attaccanti e poterne rilevare e studiare gli effetti sulla rete.

Il secondo parametro (detection rate) indica l'efficacia delle misure di sicurezza del sistema e quindi la capacità della rete di rilevare le minacce. Il parametro è correlato al livello di rumore generato dall'attaccante e rilevato dal sistema. Questo parametro permette di attribuire un determinato valore alla capacità difensiva della rete ed aumenta così il realismo; per facilitare alla simulazione la rilevazione degli attacchi questa metrica viene impostata ad un valore di 0,08.

4.3 Metriche

Il confronto tra le diverse strategie, sia statiche che dinamiche, è stato condotto ricavando dalla simulazione tre categorie di metriche delle prestazioni che poi sono state confrontate con altri risultati. La prima metrica concerne la distribuzione degli esiti, ovvero la misurazione percentuale di tassi di successo, di fallimento e di rilevamento. Questa è la più rilevante e costituisce l'elemento principale per la valutazione dei risultati del lavoro. Dobbiamo ricordare che il tasso di fallimento, per le modalità di funzionamento del simulatore, si attesta in maniera praticamente costante per tutte le strategie analizzate in un valore non inferiore al 74%, e pertanto non è stato utilizzato per le valutazioni. La seconda categoria è relativa ai dati inerenti il costo logico dell'intrusione ed è finalizzata a quantificare l'efficienza dell'attaccante attraverso la rilevazione del tempo virtuale medio impiegato e del numero medio di passi di attacco. La terza categoria infine valuta la capacità dell'attaccante di esplorare la rete, e quindi la sua pervasività, attraverso il conteggio dei percorsi unici scoperti.

Le metriche ottenute sono state, a loro volta, elaborate così da ricavare ulteriori medie ed i relativi intervalli di confidenza al 95% su cui effettuare i raffronti e le valutazioni finali.

4.4 Analisi delle Baseline

Come anticipato, la prima analisi è stata effettuata sulle strategie statiche assunte come baseline in modo da costituire il riferimento per il confronto con le successive performance delle strategie dinamiche.

4.4.1 NoisyGoalOriented

La prima strategia analizzata è stata NOISYGOALORIENTED, che all'interno delle analisi è risultata costituire il limite inferiore delle prestazioni dell'intero studio. Questa euristica infatti presenta un tasso di successo minimo, pari appena al 2,20% ed un tasso di rilevamento del 22,98%. A fronte della inefficienza sopra rilevata, il tempo medio registrato è invece molto basso, circa 10,86 ore simulate. Questi valori positivi non bastano comunque a compensare le scarse prestazioni in termini di successo e rilevamento, che producono quindi un'intrusione inefficiente, a causa principalmente dalla natura caotica e assai rumorosa della strategia.

4.4.2 GreedyValue

Un approccio più efficace è rappresentato da GREEDYVALUE che, orientando le decisioni verso i target dal valore maggiore, innalza il tasso di successo raggiungendo il 14,34%, con una buona velocità di esecuzione (20,22 ore simulate), ma mantiene un tasso di rilevamento abbastanza elevato che si aggira intorno al 10,86% e ciò perché, come visto nel Capitolo 3, la strategia non considera la quantità di rumore esponendosi così al rilevamento.

4.4.3 Stealth

La performance della terza strategia - STEALTH - risulta migliore rispetto a quella delle due precedenti. Privilegiando infatti i movimenti elusivi e le azioni non superflue, questa euristica riesce a diminuire il tasso di intercettazione portandolo al 9,82% ed a garantire un ottimo tasso di successo pari al 15,36%. Di contro il costo logico di questo approccio, focalizzato a mantenere il rilevamento più basso possibile, è l'aumento significativo del tempo di intrusione che arriva a 51,04 ore simulate. Questo aumento deriva dalla decisione della strategia di attendere, per un periodo di tempo prestabilito, prima di continuare l'intrusione, riducendo così il livello di rumore globale.

4.4.4 MaxProbability

Tra le strategie baseline quella che ottimizzare al meglio il trade-off tra efficacia ed efficienza è MAXPROBABILITY. Sfruttando matematicamente la vulnerabilità a maggiore punteggio di gravità *CVSS* ad ogni bivio decisionale, questa strategia massimizza il tasso di successo complessivo, arrivando al 15,61% e minimizza contemporaneamente il tasso di rilevamento, conseguendo un risultato anche migliore dell'approccio di STEALTH, portandolo al 9,61%. Oltre ad ottimizzare questo trade-off, l'euristica mantiene un tempo medio ottimale di 20,42 ore simulate, confermandosi come modello statico più performante.

Tabella 4.1: Confronto delle metriche principali tra le strategie statiche (baseline) su $N = 100$ campagne di simulazioni.

Strategia	Successo (%)	Rilevamento (%)	Tempo Medio (ore)
NoisyGoalOriented	2.2	22.98	10.86
GreedyValue	14.34	10.86	20.22
Stealth	15.36	9.82	51.04
Maxprobability	15.61	9.61	20.42

Dalla tabella sinottica riportata sopra si può osservare che NOISYGOALORIENTED ottiene le prestazioni peggiori delle quattro strategie baseline, con un successo del 2,20% e un rilevamento del 22,98%. L'approccio di GREEDY-VALUE, invece, innalza il successo fino al 14,34% al prezzo di un rilevamento pari al 10,86%, la strategia STEALTH, da parte sua, garantisce un'elusività ancora migliore (9,82%) a fronte però di tempi particolarmente elevati pari ad una media di 51,04 ore. I risultati migliori sono inequivocabilmente raggiunti da MAXPROBABILITY, che massimizza il successo al 15,61% e minimizza il rilevamento al 9,61%, mantenendo comunque un'elevata efficienza operativa, con un tempo medio di 20,42 ore.

4.5 Analisi di SwitchOnStall

Come visto nel Capitolo 3 questa strategia combina due euristiche statiche della baseline. In una prima configurazione utilizza un fattore k di stallo per risolversi al mutamento del comportamento da seguire; in una seconda configurazione utilizza un ulteriore parametro h per determinare il numero dei passi prima di tornare alla strategia primaria. Per questo studio sono state create e testate 5 combinazioni di strategie - (*Noisy* $\rightarrow$ *Greedy*), (*Noisy* $\rightarrow$ *MaxProb*), (*Greedy* $\rightarrow$ *Stealth*), (*Stealth* $\rightarrow$ *MaxProb*) e (*MaxProb* $\rightarrow$ *Greedy*) - configurate in un primo momento solo per il parametro k , assumendo k per 1, 2, 3, 4, 5, 6 e poi configurate anche per il parametro h , assumendo h per 5, 10, 15, 20, 25, 30.

I dati raccolti* nel corso dell'analisi delle strategie dinamiche, hanno evidenziato che queste, a differenza di quelle baseline, possono raggiungere una stabilità statistica solo molto avanti nella campagna di simulazione. Lo scambio e la combinazioni di più strategie crea dei percorsi e delle combinazioni di nodi unici, facendo sì che l'euristica non riesca a stabilizzarsi entro il limite di simulazioni prestabiliti, interrompendosi la simulazione nella totalità dei casi per il raggiungimento del limite.

*I risultati completi di tutte le analisi effettuate in questo lavoro sono esposti nelle tabelle riportate in appendice.

4.5.1 Studio del parametro k

Nell'ambito della prima configurazione (**NoisyToGreedy**) i miglioramenti più evidenti emergono analizzando le combinazioni che presentano NOISY come strategia primaria che, utilizzata in maniera statica registra appena il 2,20% di successo e un 22,98% di rilevamento. Nella combinazione con GREEDY come strategia secondaria l'introduzione di k impostato a 1, ovvero una transizione immediata al primo fallimento, innalza il tasso di successo al 14,20%, registrando un incremento netto del 12% rispetto alla baseline, ed abbatta il rilevamento al 11,03%, un miglioramento quindi del 11,95%. All'aumentare di k , le prestazioni degradano, giungendo per $k = 6$ ad una percentuale di successo che crolla al 8,59% e con la percentuale di rilevamento che risale al 16,60%. Per quanto riguarda il tempo medio di simulazione si registra un aumento generale ed uniforme il cui valore tende ad allinearsi a quello della strategia secondaria.

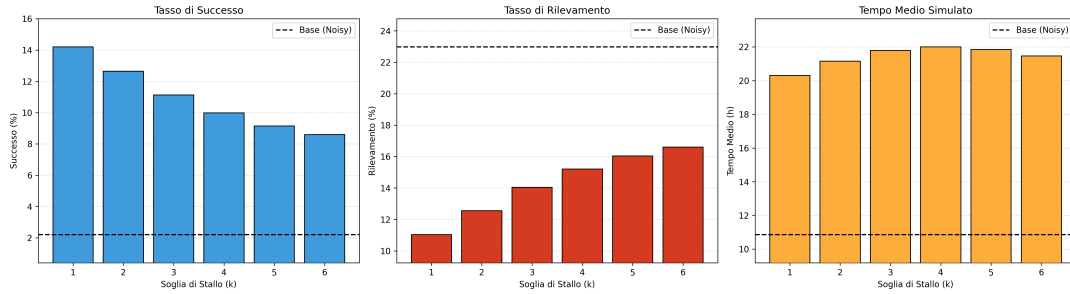


Figura 4.1: Confronto metriche principali della configurazione NOISYTO-GREEDY

Un risultato molto simile, ma con prestazioni superiori, si osserva nella combinazione tra NOISY primaria e MAXPROB secondaria (**NoisyToMaxProb**). Anche in questo caso l'impostazione di $k = 1$ fa aumentare il successo al 15,35%, con un +13,15% sulla baseline, e confina il rilevamento al 9,83%, con una diminuzione del -13,15%. Anche in questo caso, l'incremento di k deteriora le prestazioni, facendo scendere il successo al 8,77% e innalzando il rilevamento al 16,41%. Per quanto riguarda il valore del tempo medio di simulazione, vale quanto già detto per la configurazione precedente.

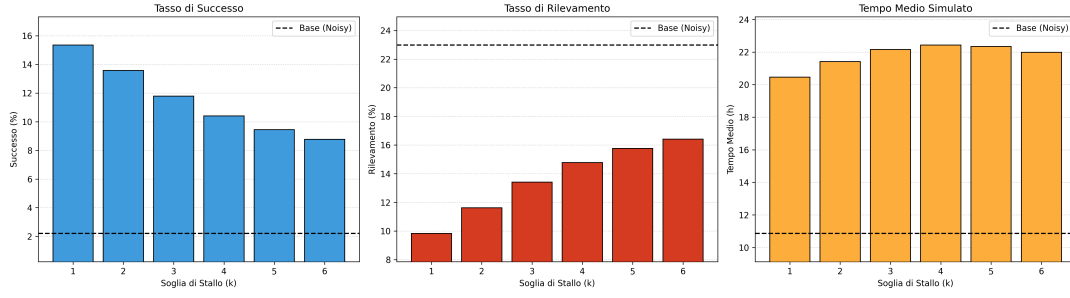


Figura 4.2: Confronto metriche principali della configurazione NOISYTO-MAXPROB

L'adozione di una transizione rapida, ovvero $k = 1$, risulta efficace anche quando impiegata per compensare le lacune di una strategia più efficaci rispetto a NOISY quale GREEDY: nella combinazione di GREEDY e STEALTH (**GreedyToStealth**) infatti l'euristica secondaria riesce ad attenuare l'irruenza tipica della prima. Impostando infatti $k = 1$ la variante dinamica migliora le proprie prestazioni, aumentando il successo del 1% ed arrivando ad un risultato di 15,34% con una riduzione del rilevamento del 1,02%, ed un valore che si stabilizza intorno al 9,84%. Coerentemente con le altre analisi, tolleranze (k) più alte comportano un riallineamento verso le strategie statistiche baseline. In questo caso, la migliore prestazione ottenuta si paga in termini di tempo di esecuzione, che per valori di k bassi si allinea a quello della baseline STEALTH, arrivando anche a 50,96 ore medie simulate.

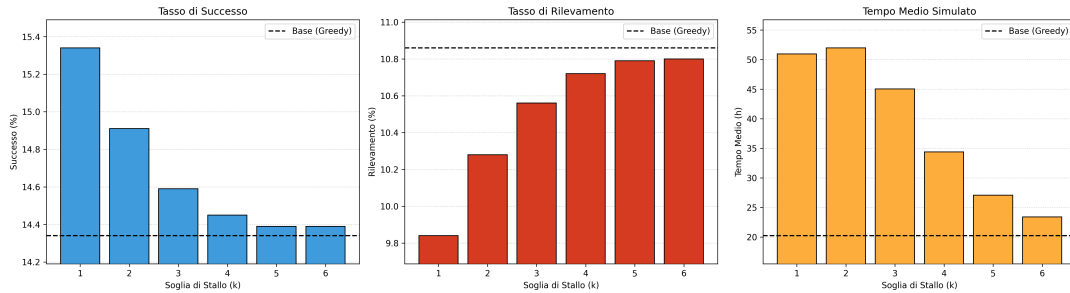


Figura 4.3: Confronto metriche principali della configurazione GREEDYTO-STEALTH

Molto interessanti sono i risultati della combinazione STEALTH e MAXPROB (**StealthToMaxProb**). La strategia primaria statica garantiva infatti buoni tassi di elusione e di successo, ma richiedeva tempi lunghi. Innescando con $k = 1$ la deviazione verso l'euristica probabilistica di MAXPROB, l'agente migliora, seppur di poco, il tasso di successo registrando un incremento dello 0,24% del successo, con risultato finale del 15,60% ed una diminuzione del rilevamento dello 0,23% arrivando al 9,59% finale. L'agente ottiene però un beneficio importante sul tempo di esecuzione che viene ridotto in maniera drastica di oltre 30 ore medie, arrivando a 20,40 ore medie simulate. Anche

in questa ibridazione, l'aumento del parametro k peggiora le percentuali e fa aumentare nuovamente i tempi operativi.

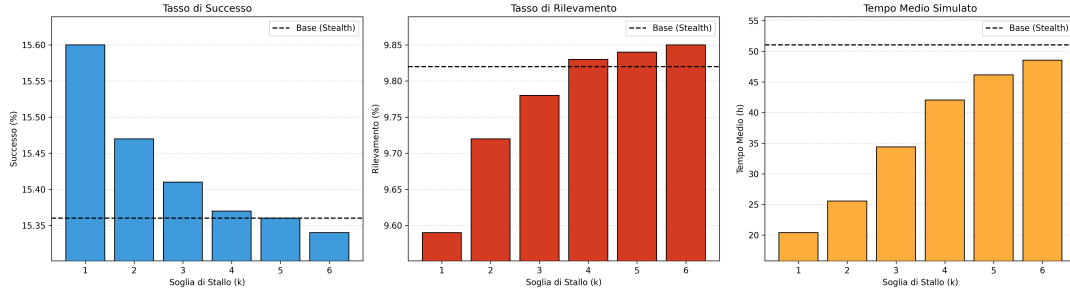


Figura 4.4: Confronto metriche principali della configurazione STEALTHToMAXPROB

Il risultato opposto si ha con la combinazione di MAXPROB e GREEDY (**MaxProbToGreedy**). Introdurre nell'euristica primaria, che staticamente risulta la migliore tra le quattro, un abbandono forzato e prematuro è una scelta controproducente perchè le sue ibridazioni faticano a superare le prestazioni di base. I dati mostrano infatti che, diversamente dalle altre combinazioni, aumentare la soglia di k migliora gradualmente le prestazioni dell'ibrido, portando con $k = 6$ un tasso di successo del 15.57% e di rilevamento a 9.61%. Con questo valore di k si possono ottenere delle prestazioni sostanzialmente equivalenti rispetto alla strategia stratica. Il tempo medio simulato (20,37) è il più alto tra le varie configurazioni, ma comunque inferiore, seppur di poco, rispetto al valore della baseline di 20,42 ore.

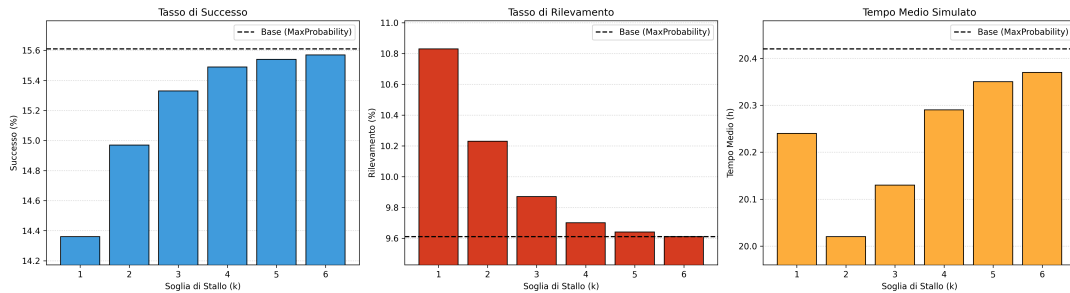


Figura 4.5: Confronto metriche principali della configurazione MAXPROBABILITYToGREEDY

4.5.2 Studio del parametro h

Dopo aver eseguito le analisi di questa strategia dinamica utilizzando solo il valore k , si è introdotto il parametro di ritorno h studiandone gli effetti ed il conseguente cambiamento del comportamento dell'euristica. Il parametro h è stato impostato da $h = 5$ a $h = 30$ con step di 5 e l'analisi è stata effettuata combinando ciascun valore di k con i valori di h . Il risultato più

evidente, come riportato nelle tabelle, è che nell'ambito di ciascun valore k , il mutare di h determina una minima variazione di risultati del tasso di successo e di rilevamento in tutte le strategie, con variazioni i cui valori sono contenuti nell'ordine dei centesimi; ugualmente minima è la variazione rispetto ai risultati delle configurazioni con il solo parametro k (baseline).

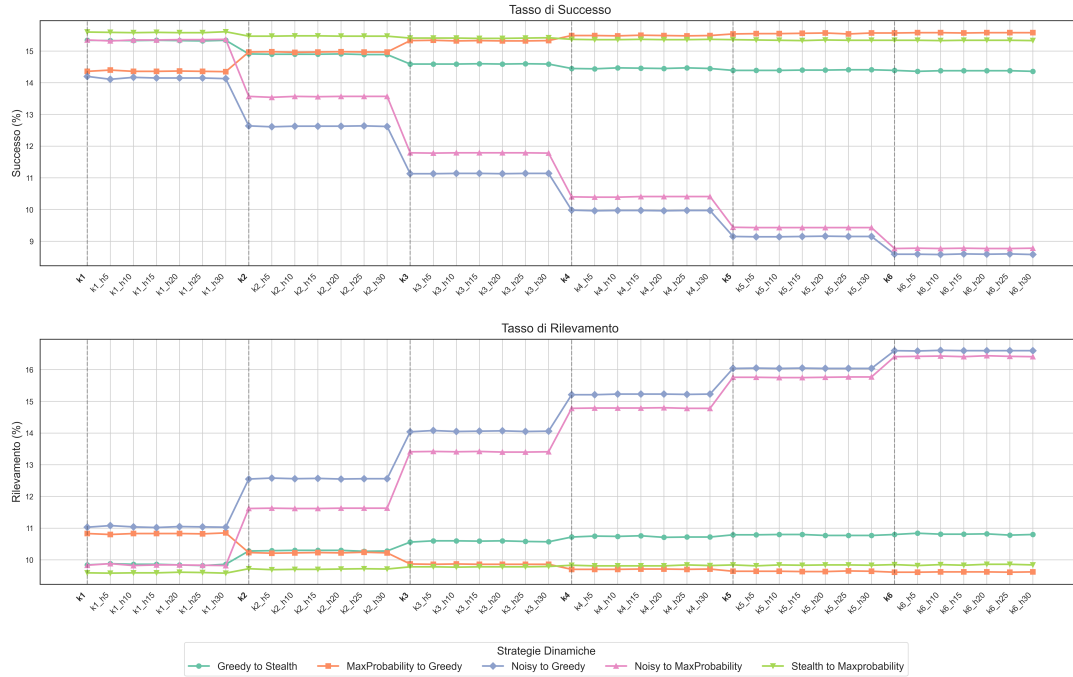


Figura 4.6: Confronto del tasso di successo e di rilevamento al variare di k e h per ogni strategia

Diverso il comportamento del tempo medio di simulazione che, con l'inserimento di h nelle strategie dinamiche, varia in funzione del tipo di strategia secondaria utilizzata. Si è detto che h determina il numero di azioni che la strategia dinamica esegue con la logica secondaria: ne deriva che in presenza di una strategia secondaria caratterizzata da un tempo medio di simulazione alto avremo un incremento dal tempo medio di simulazione dinamica all'aumentare di h . Invece, in presenza di una strategia secondaria caratterizzata da un tempo medio di simulazione basso avremo un decremento dal tempo medio di simulazione dinamica all'aumentare di h .

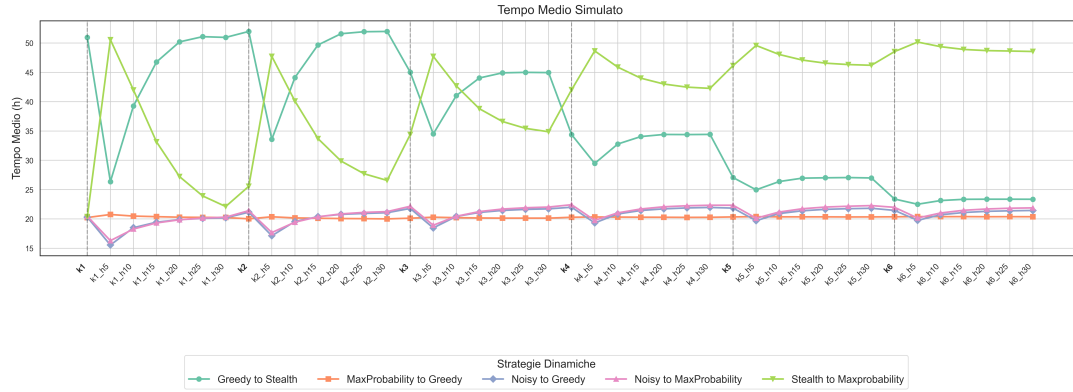


Figura 4.7: Confronto del tempo medio simulato di k e h per ogni strategia

Verificata la marginalità delle conseguenze al variare di h sui risultati di successo e di rilevamento, sarà riportata, a titolo di esempio, l'analisi delle simulazioni effettuate impostando $k = 2$, il valore migliore per osservare gli effetti del ritorno alla strategia primaria. Impostando la soglia di stallo $k = 2$ infatti gli effettivi cambi di strategia avvengono dopo un numero sufficiente di nodi, simulando perfettamente il comportamento ideale di SWITCHON-STALL. Infatti, questo valore in ogni strategia è secondo per prestazioni solo a $k = 1$, parametro che però provoca uno scambio troppo veloce da primaria a secondaria che non ci permette di studiare gli effetti desiderati. Sono state compiute 100 campagne di simulazione per ogni valore di h sopra elencato.

Iniziando l'analisi dalla strategia **NoisyToGreedy** si può verificare che, nonostante l'introduzione di un ritorno alla strategia di partenza NOISY, che abbiamo visto essere molto poco performante, le prestazioni dell'ibrido migliorano rispetto a quelle della sua baseline. I dati mostrano che anche eseguendo solo 5 passi di GREEDY il tasso di successo raggiunge il 12,61%, registrando un incremento di 10,40 punti percentuali. Parallelamente, l'abbandono temporaneo delle logiche caotiche e rumorose di NOISY quasi dimezza il rilevamento, facendolo scendere al 12,58%. Aumentando ancora la finestra con $h = 25$ la strategia raggiunge il picco di successo del 12,64%, con un valore di rilevamento del 12,56%.

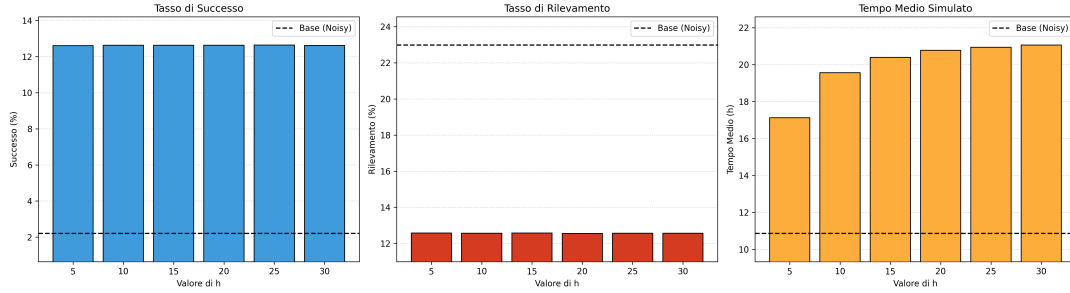


Figura 4.8: Confronto metriche principali della configurazione NOISYTO-GREEDY con parametro h

Risultati ancora migliori emergono dalla fusione **NoisyToMaxProb**. In questa combinazione MAXPROB, l'euristica migliore delle 4 baseline, riesce a migliorare ulteriormente le prestazioni generali, raggiungendo già a partire da $h = 20$ di un tasso di successo del 13,57% ed un tasso di rilevamento del 11,63%.

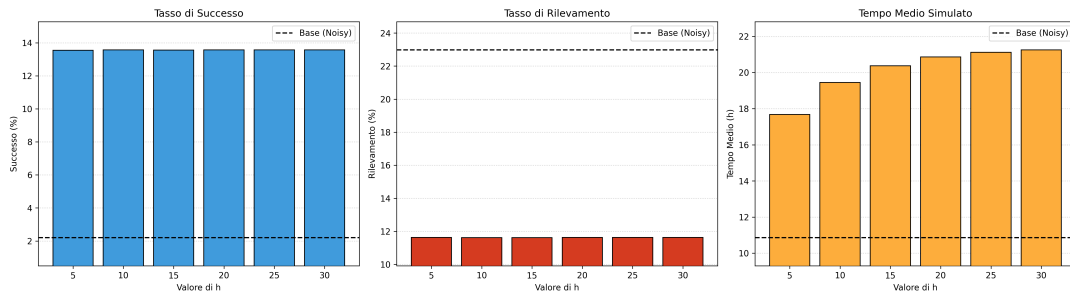


Figura 4.9: Confronto metriche principali della configurazione NOISYTO-MAXPROB con parametro h

Analizzando l'introduzione del valore h sulla configurazione **GreedyToStealth** è possibile notare che già per $h = 5$, i valori di successo e rilevamento migliorano molto, passando rispettivamente dal 14,34% al 14,90% e dal 10,89% al 10,29%. Si rileva inoltre che utilizzando come secondaria una strategia prudente quale Stealth, all'aumentare della finestra di esecuzione h , aumenta necessariamente anche il tempo medio di simulazione. Si ottiene un giusto compromesso mantenendo con $h = 5$ un intervento rapido con un valore di 33,58, incrementando l'esecuzione solo di 13,36 ore medie.

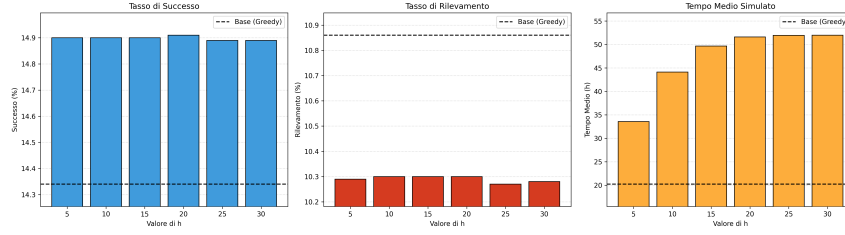


Figura 4.10: Confronto metriche principali della configurazione GREEDY-ToSTEALTH con parametro h

Nell'analisi della combinazione di **StealthToMaxprob**, è interessante notare come, a causa della natura già ottima della strategia di partenza, anche una limitata deviazione a MAXPROB sia sufficiente per incrementare il successo, con un trade-off minimale per quanto riguarda il rilevamento. Con $h = 15$ infatti la strategia ibrida raggiunge il 15,48% di successo (+0,12% rispetto alla baseline STEALTH) e migliora il rilevamento di $-0,12\%$ con un valore di 9,7%. Il vero tratto caratteristico di questa variante è che con l'aumentare di h la strategia riesce a migliorare ulteriormente il tempo di esecuzione. Impostando $h = 30$ infatti, ovvero lasciando molto spazio a MAXPROB, il tempo medio di simulazione raggiunge 26,57 ore, quasi dimezzando il valore della strategia statica, al costo di uno scarto di 0,01% sul valore di successo più alto e di 0,02% sul valore di rilevamento più basso tra le configurazioni.

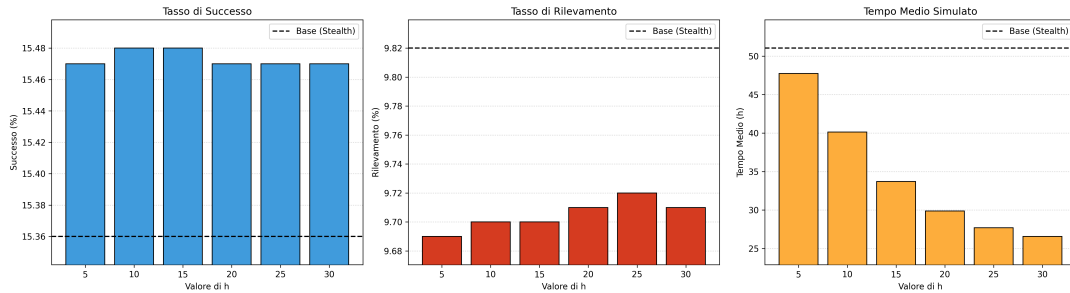


Figura 4.11: Confronto metriche principali della configurazione STEALTH-ToMAXPROB con parametro h

Considerazioni analoghe valgono per la combinazione **MaxProbToGreedy**: anche in questo caso l'elevata efficienza della strategia statica primaria MAXPROB fa sì che l'utilizzo della secondaria (meno efficiente) per il valore di passi indicato dal parametro h determini un peggioramento delle prestazioni. Infatti, il successo scende al 14,98% e il rilevamento si innalza al 10,21%, con una variazione rispettivamente di $-0,63\%$ e di $+0,60\%$. Da segnalare che nonostante questo calo generale di prestazioni la configurazione riesce a

mantenere un buon tempo di esecuzione, in molti casi migliore rispetto alla baseline di MAXPROB.

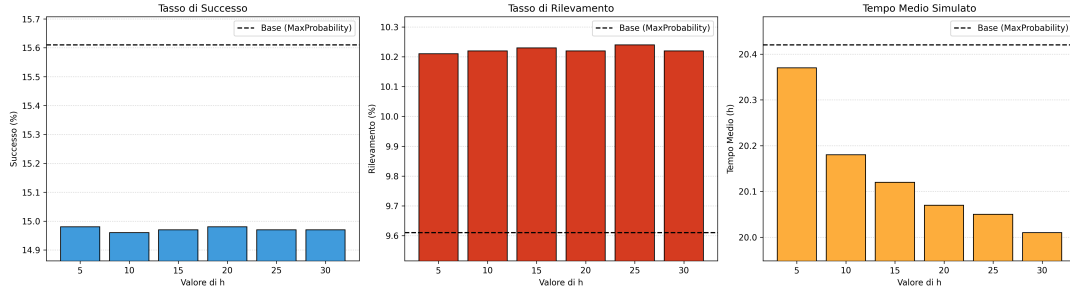


Figura 4.12: Confronto metriche principali della configurazione MAXPROB-TOGREEDY con parametro h

In sintesi è stato possibile osservare che l'introduzione del parametro di ritorno h non ha portato cambiamenti significativi alle varie metriche di confronto rispetto alla loro variante con il solo parametro di stallo k , pur migliorando comunque i risultati rispetto alle rispettive strategie baseline.

4.6 Analisi SimulatedAnnealing

L'architettura dinamica basata su Simulated Annealing introduce un valore di temperatura T che l'euristica gestisce utilizzando specifici parametri per la sperimentazione e lo studio del variare delle combinazioni. Il punto di partenza è una temperatura iniziale T_0 , che si incrementa di un predeterminato ΔT ogniquale volta che non viene raggiunto il goal, fino al raggiungimento di una soglia massima T_{max} . La temperatura viene usata per calcolare la probabilità di eseguire un cambio di strategia " $p(T)$ "; la probabilità viene calcolata o come $\min(1, \frac{T}{T_{max}})$ o utilizzando una funzione esponenziale o sigmoidea equivalente. Determinato il mutamento di strategia, viene eseguita, come secondaria, MAXPROB per un numero definito di passi (L), al termine dei quali la temperatura viene ridotta tramite un meccanismo di raffreddamento mediante il prodotto con un valore decimale γ .

Data l'elevata dimensione dello spazio dei parametri che regolano la strategia di SIMULATEDANNEALING, la ricerca della configurazione ottimale è stata eseguita mediante un framework ausiliario di ottimizzazione iperparametrica, *Optuna* [11] che, interfacciato con un campionatore TPE (*Tree-structured Parzen Estimator*), effettua una analisi del range dei parametri. La "qualità" di ogni configurazione è stata misurata attraverso una funzione di fitness, che ha il compito di premiare le configurazioni con il miglior rapporto tra tasso di successo, tasso di rilevamento e tempo; ai premi attribuiti si sommano anche dei bonus o dei malus aggiuntivi determinati dal superamento o meno delle

prestazioni delle strategie di base STEALTH per il rilevamento e di MAXPROB per il successo.

Il framework è stato configurato per eseguire 300 Trial indipendenti e per contenere il tempo di esecuzione. Durante la fase esplorativa, la funzione obiettivo del framework ha valutato ottimale un numero ridotto di ripetizioni, ovvero 20 iterazioni per trial, composte da 500 intrusioni simulate. Questa breve esplorazione consente di isolare un numero limitato di configurazioni poi validate statisticamente eseguendo 100 campagne di simulazione per ciascuna. Ogni campagna è composta 30.000 simulazioni singole, di cui poi calcolano medie e i relativi intervalli di confidenza al 95%. Per questo studio sono state isolate 5 configurazioni da analizzare, e della migliore sono state testate anche varianti con le diverse tipologie di funzioni per il calcolo probabilistico. Le strategie studiate sono le seguenti:

Tabella 4.2: Migliori Configurazioni e Parametri di SIMULATEANNEALING

Configurazione	T0	delta_T	T_max	gamma	L	p(T)
Top1	1.00	2.00	5.00	0.70	5	linear
Top2	1.00	2.00	5.00	0.90	5	linear
Top3	1.50	1.25	7.50	0.60	4	linear
Top4	1.50	1.75	10.00	0.60	2	exponential
Top5	2.00	1.25	5.00	0.90	5	linear
Top1_Variant_sigmoid	1.00	2.00	5.00	0.70	5	sigmoid
Top1_Variant_exponential	1.00	2.00	5.00	0.70	5	exponential

Dall'esame delle simulazioni effettuate utilizzando le configurazioni più promettenti si ricava che la prima fase STEALTH e le successive esplorazioni con MAXPROB, non bastano per migliorare significativamente le prestazioni rispetto a quelle ottenute da solo MAXPROB. Il massimo risultato infatti è stata una sovrapposizione dei rispettivi intervalli di confidenza, sia per quanto riguarda il successo che per quanto riguarda il rilevamento. Le prestazioni invece sicuramente sono superiori rispetto a quelle di STEALTH con un successo mai inferiore al 15,50% ed un rilevamento mai superiore al 9,80%.

L'analisi dei risultati alla luce dei parametri utilizzati ha permesso di verificare che le configurazioni con migliori prestazioni sono quelle più "impazienti", quindi con valore T_{max} basso e con valore ΔT alto, configurazioni che determinano un elevato innalzamento della temperatura in breve tempo. Anche l'impostazione di $T_0 \geq 1$ risulta più efficace, così come l'impostazione $\gamma \geq 0,6$. Per quanto riguarda il numero di passi (L) ed il calcolo della probabilità ($p(T)$), si è verificato che un valore L elevato (4-5) migliora le prestazioni, il variare di $p(T)$ ha un impatto minore dato che il framework utilizza gli altri parametri per ottenere risultati buoni con tutti e tre i tipi di funzioni.

In conclusione, i risultati di questa strategia, che dovrebbe migliorare le prestazioni di MAXPROB, hanno dimostrato che, pur senza ottenere un netto miglioramento, si possono ottenere prestazioni analoghe a MAXPROB utilizzando valori bassi di T_{max} e valori elevati di L . I risultati hanno altresì dimostrato che l'introduzione, all'interno di strategie ibride, di un criterio di cambio del paradigma decisionale più complesso come quello della temperatura determina un complessivo miglioramento delle prestazioni rispetto alle altre soluzioni dinamiche considerate.

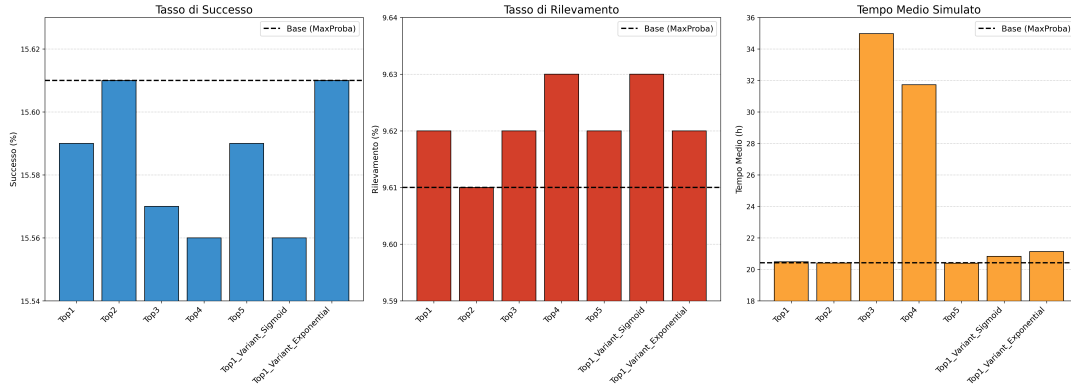


Figura 4.13: Confronto metriche principali della strategia SimulatedAnnealing

4.7 Analisi StochasticMaxProb

Verificato che MAXPROB risulta essere la strategia più performante, è stato ritenuto interessante realizzarne una versione in cui viene introdotto un elemento stocastico di perturbazione (p), così da portare l'euristica ad esplorare percorsi non considerati dalle sue modalità di esplorazione "ordinarie" e mitigare il problema della prevedibilità statistica. Quest'ultimo aspetto non influenza le prestazioni all'interno di questo motore di simulazione in ragione delle sue caratteristiche, ma potrebbe rivestire un peso rilevante utilizzando altri e diversi motori. In questo studio, il nuovo fattore introdotto è stato impostato, utilizzando valori di probabilità p compresi tra 0,5% e 10%, in maniera tale da indurre una variazione controllata e tale da non impattare troppo sul comportamento originale della strategia.

Il primo risultato che si nota è che già con $p = 0,50\%$ il tasso di successo è del 15,57% per poi stabilizzarsi comunque in un range compreso tra 15,55% e 15,56% all'incremento di p . Il comportamento più interessante però si ricava dai valori del rilevamento. Con l'introduzione di questi comportamenti casuali, l'euristica riesce a limitare ulteriormente il proprio rumore: il rilevamento infatti, a fronte di valori della baseline del 9,61% , scende a valori compresi tra 9,57% e 9,59%. Il tempo medio, pur non diminuendo, si mantiene comunque accettabile attestandosi intorno alle 30 ore medie di simulazione.

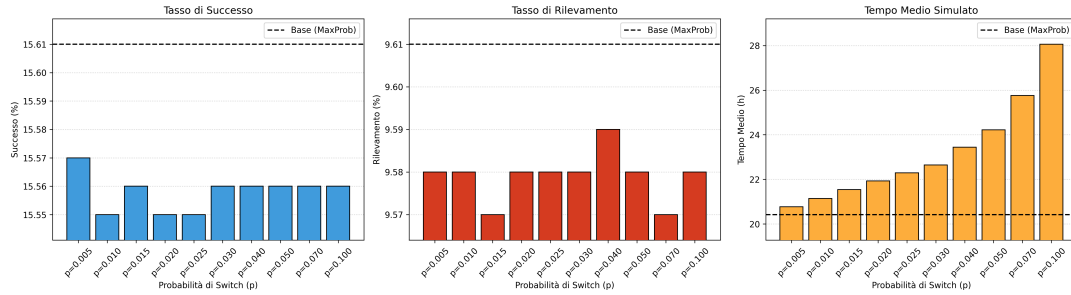


Figura 4.14: Confronto metriche principali della strategia STOCHASTIC-MAXPROB

In sintesi, pur non avendo superato la baseline per tutti i valori, questa strategia rispetto a MAXPROB ha fatto registrare dei miglioramenti dell'elusività a discapito soltanto di pochi punti percentuali sul tasso di successo.

All'esito delle simulazioni e dell'analisi delle possibili strategie e delle combinazioni tra di loro, MAXPROB risulta avere delle prestazioni superiori a tutte le altre, anche quelle dinamiche. Il fattore determinante per il raggiungimento di uno score elevato da parte di MAXPROB può essere individuato nella logica decisionale della scelta del target. Nel contesto in cui sono stati simulati questi comportamenti, la scelta di attaccare sempre il nodo più vulnerabile è risultata sempre la migliore. In base alle caratteristiche del motore di simulazione infatti, la vulnerabilità incide molto sulla probabilità di successo di un exploit, e per questa ragione la logica probabilistica migliora le prestazioni non solo di successo ma anche di rilevamento. Tentando l'attacco un numero inferiore di volte, la strategia produce meno rumore riuscendo così ad essere più furba della strategia STEALTH stessa. Questa superiorità di euristica è confermata anche dal fatto che a parità di scelta dell'azione, tra GREEDY e MAXPROB si ha una differenza di successo e di rilevamento rispettivamente del +1,27% e del -1,25%, che deriva proprio dalle modalità di individuazione del target da parte della seconda strategia.

Capitolo 5

Conclusioni

Questo lavoro ha progettato, analizzato e valutato le prestazioni di diverse strategie di intrusione utilizzando come ambiente di sperimentazione un *Security Twin*. Attraverso l'utilizzo del motore di simulazione, basato sul metodo Monte Carlo, messo a disposizione dalla piattaforma NOTLINE, è stato possibile studiare il comportamento di diversi tipi di attaccanti all'interno di un twin di un sistema, osservandone le interazioni, le scelte operative e l'impatto sul sistema.

In una prima fase sono state ricavate da quattro strategie statiche le baseline da utilizzare poi come termine di paragone per i successivi confronti. I dati raccolti hanno dimostrato che un approccio caotico e rumoroso (NOISYGOALORIENTED) determina tassi di successo e di rilevamento insoddisfacenti; al contrario, un approccio basato sulla valutazione delle probabilità di successo utilizzando il punteggio di gravità *CVSS* delle vulnerabilità del target (MAXPROBABILITY) riesce a massimizzare il successo dell'attacco ed a minimizzare i tempi di esecuzione nonché la probabilità di rilevamento. Le altre due strategie, GREEDYVALUE e STEALTH, hanno conseguito dei risultati intermedi, tra i quali però si deve segnalare un elevato tempo medio simulato della seconda.

Partendo dai dati raccolti, si è analizzato come la combinazione di queste euristiche statiche ed il passaggio dall'una all'altra, determinato da diversi criteri di transizione, potesse impattare sulle prestazioni ed eventualmente migliorarle.

La prima strategia dinamica (SWITCHONSTALL) ha utilizzato diverse combinazioni di euristiche statiche che si alternano al raggiungimento di una condizione di stallo nell'avanzamento dell'intrusione. I risultati ottenuti dimostrano che la peggiore delle strategie statiche (NOISYGOALORIENTED), proprio per le sue scarse caratteristiche di partenza, viene migliorata da qualsiasi ibridazione; allo stesso modo l'approccio ibrido consente di compensare in parte le caratteristiche meno preformanti delle altre euristiche, riducendo quindi il tempo medio simulato di STEALTH e migliorando successo e rilevamento di

GREEDYVALUE. L'analisi ha inoltre confermato il primato prestazionale di MAXPROBABILITY che non trae ulteriori significativi benefici dal suo utilizzo in combinazione con altre strategie. Si deve dire che questo risultato è anche la conseguenza della particolare configurazione del motore di simulazione utilizzato, che attribuisce preponderante rilevanza al valore di vulnerabilità dei singoli nodi per calcolare la probabilità di successo, e questo coincide esattamente con il principio su cui si basa la decisione di MAXPROBABILITY.

Si è poi utilizzato, per l'alternanza tra fasi furtive e momenti probabilistici più aggressivi, un criterio di transizione maggiormente sofisticato quale il parametro della temperatura di SIMULATEDANNEALING. I risultati hanno evidenziato che, utilizzando le medesime strategie statiche di base, il ricorso ad un criterio più complesso migliora le performance dell'approccio dinamico, sia in rapporto alla baseline, che alla combinazione regolata dal criterio di stallo. I risultati hanno altresì confermato l'estrema efficienza di MAXPROBABILITY che anche qui offre le prestazioni migliori.

Riscontrata ancora una volta la sua superiorità, si è verificata la possibilità di migliorare l'efficienza di MAXPROBABILITY creandone una variante (STOCHASTICMAXPROB) che attraverso un fattore stocastico induca deviazioni decisionali non tipiche della strategia. Un limite della euristica MAXPROBABILITY risiede infatti nel suo punto di forza, ovvero la scelta di target più facilmente compromettibili che si traduce conseguentemente in una prevedibilità dei suoi pattern. Dai risultati ottenuti si può ricavare che l'introduzione della variabile stocastica ha prodotto una minima riduzione delle percentuali di successo ma di contro ha consentito un miglioramento dell'elusività della strategia. Sembra opportuno puntualizzare che questa combinazione dinamica, pur conseguendo dei risultati interessanti all'interno del motore di simulazione di NOTLINE, può produrre risultati ancora più apprezzabili con altri motori di simulazione maggiormente realistici. Altri motori, infatti, a differenza di quello utilizzato per questo lavoro, possono analizzare pattern di comportamenti, profilare l'attaccante e prevenirne le mosse, rendendo maggiormente importante per la strategia la possibilità di rendere il proprio comportamento imprevedibile.

La scoperta che STOCHASTICMAXPROB, rompendo gli schemi di MAXPROBABILITY, riesca ad ottenere un valore di rilevamento inferiore rispetto a quello, già ottimale, della versione statica, mette a nudo un limite rilevante dei sistemi di sicurezza basati prevalentemente sul riconoscimento delle firme comportamentali (*signature-based*). Un attaccante infatti che sia in grado di delineare il proprio pattern decisionale ricorrendo anche a deviazioni stocastiche, può riuscire facilmente a superare i sistemi di detezione tarati su percorsi di intrusione rigidi e prevedibili.

Come si è visto, il motore di simulazione, ed ovviamente l'ambiente, influenzano in maniera significativa le prestazioni delle varie strategie e ciò renderà opportuno effettuare ulteriori approfondimenti sperimentali per confermare

la validità dei risultati anche usando differenti *Security Twin*: morfologie differenti di reti potrebbero infatti incidere sul comportamento delle euristiche producendo risultati differenti.

Stesse considerazioni si devono fare per il motore di simulazione utilizzato: compiere l'analisi anche attraverso ulteriori motori di simulazione farebbe sì che il risultato ottenuto venga validato ricorrendo a logiche diverse ed a diverse modalità operative dei codici utilizzati. Questo potrebbe evidenziare eventuali bias presenti in un singolo motore di simulazione consentendone la correzione.

Questo studio, in conclusione, partendo dall'analisi di strategie tradizionali in sistemi di difesa tradizionali, ha ideato e studiato, tramite *Security Twin*, strategie dinamiche sempre più avanzate che hanno messo in luce e superato i limiti delle prime conseguendo un netto miglioramento delle performance.

Un interessante sviluppo di questo lavoro potrebbe essere quello di esaminare la questione dal punto di vista della difesa verificando l'efficacia di queste stesse strategie in presenza di un difensore dinamico che sia in grado di adattare le misure di difesa agli attacchi, aggiungendo in tal modo un ulteriore grado realismo.

* * *

* *

*

Appendice

I Risultati simulazioni di NoisyToGreedy

Tabella 1: Confronto delle metriche per la strategia NOISYTOGREEDY al variare di k e h .

Configurazione	Successo (%)	Fallimento (%)	Rilevamento (%)	Passi Medi	Tempo Medio (ore)
$k = 1$	14.20	74.78	11.03	5.08	20.31
$h = 5$	14.11	74.81	11.08	3.86	15.55
$h = 10$	14.17	74.80	11.04	4.61	18.51
$h = 15$	14.15	74.82	11.02	4.86	19.45
$h = 20$	14.15	74.80	11.05	4.97	19.88
$h = 25$	14.15	74.81	11.04	5.02	20.09
$h = 30$	14.13	74.83	11.03	5.05	20.19
$k = 2$	12.64	74.81	12.55	5.03	21.15
$h = 5$	12.61	74.81	12.58	4.01	17.13
$h = 10$	12.63	74.81	12.56	4.63	19.56
$h = 15$	12.63	74.80	12.57	4.84	20.39
$h = 20$	12.63	74.82	12.55	4.94	20.78
$h = 25$	12.64	74.80	12.56	4.98	20.94
$h = 30$	12.62	74.81	12.56	5.01	21.06
$k = 3$	11.13	74.82	14.04	4.93	21.79
$h = 5$	11.13	74.79	14.08	4.09	18.47
$h = 10$	11.14	74.81	14.05	4.58	20.43
$h = 15$	11.14	74.81	14.06	4.76	21.11
$h = 20$	11.13	74.80	14.07	4.85	21.45
$h = 25$	11.14	74.81	14.05	4.89	21.63
$h = 30$	11.14	74.80	14.06	4.91	21.72
$k = 4$	9.98	74.80	15.21	4.78	22.00
$h = 5$	9.96	74.83	15.21	4.10	19.32
$h = 10$	9.97	74.80	15.23	4.49	20.85
$h = 15$	9.97	74.79	15.23	4.64	21.44
$h = 20$	9.96	74.81	15.23	4.71	21.72
$h = 25$	9.97	74.80	15.22	4.75	21.88
$h = 30$	9.97	74.80	15.23	4.77	21.96
$k = 5$	9.15	74.81	16.04	4.61	21.85
$h = 5$	9.14	74.81	16.05	4.07	19.70
$h = 10$	9.14	74.82	16.04	4.38	20.92
$h = 15$	9.15	74.80	16.05	4.50	21.39
$h = 20$	9.16	74.80	16.04	4.56	21.64
$h = 25$	9.15	74.81	16.04	4.59	21.75
$h = 30$	9.15	74.81	16.04	4.61	21.82
$k = 6$	8.59	74.81	16.60	4.45	21.46
$h = 5$	8.59	74.82	16.59	4.01	19.76
$h = 10$	8.58	74.81	16.61	4.26	20.71
$h = 15$	8.60	74.81	16.60	4.35	21.10
$h = 20$	8.59	74.81	16.60	4.40	21.30
$h = 25$	8.60	74.80	16.60	4.43	21.39
$h = 30$	8.58	74.82	16.60	4.44	21.45

II Risultati simulazioni di NoisyToMaxProb

Tabella 2: Confronto delle metriche per la strategia NOISYTOMAXPROB al variare di k e h .

Configurazione	Successo (%)	Fallimento (%)	Rilevamento (%)	Passi Medi	Tempo Medio (ore)
$k = 1$	15.35	74.82	9.83	5.47	20.46
$h = 5$	15.32	74.80	9.88	4.18	16.30
$h = 10$	15.36	74.82	9.82	4.79	18.28
$h = 15$	15.35	74.82	9.84	5.11	19.32
$h = 20$	15.36	74.80	9.84	5.29	19.86
$h = 25$	15.36	74.82	9.83	5.37	20.15
$h = 30$	15.37	74.81	9.82	5.42	20.31
$k = 2$	13.57	74.81	11.62	5.43	21.41
$h = 5$	13.54	74.82	11.63	4.28	17.68
$h = 10$	13.57	74.81	11.62	4.82	19.45
$h = 15$	13.56	74.82	11.62	5.11	20.37
$h = 20$	13.57	74.80	11.63	5.26	20.86
$h = 25$	13.57	74.80	11.63	5.34	21.12
$h = 30$	13.57	74.80	11.63	5.38	21.25
$k = 3$	11.79	74.80	13.41	5.32	22.16
$h = 5$	11.78	74.81	13.42	4.32	18.93
$h = 10$	11.79	74.79	13.41	4.79	20.46
$h = 15$	11.79	74.79	13.42	5.04	21.26
$h = 20$	11.79	74.81	13.40	5.17	21.69
$h = 25$	11.79	74.81	13.40	5.24	21.91
$h = 30$	11.78	74.81	13.41	5.28	22.03
$k = 4$	10.40	74.82	14.78	5.14	22.43
$h = 5$	10.39	74.82	14.79	4.31	19.76
$h = 10$	10.39	74.82	14.79	4.71	21.04
$h = 15$	10.41	74.80	14.79	4.91	21.70
$h = 20$	10.41	74.80	14.80	5.03	22.08
$h = 25$	10.41	74.82	14.78	5.09	22.25
$h = 30$	10.41	74.81	14.78	5.11	22.34
$k = 5$	9.44	74.80	15.76	4.95	22.34
$h = 5$	9.43	74.81	15.76	4.26	20.13
$h = 10$	9.43	74.82	15.75	4.58	21.18
$h = 15$	9.43	74.82	15.75	4.76	21.74
$h = 20$	9.43	74.81	15.76	4.85	22.03
$h = 25$	9.43	74.80	15.77	4.89	22.17
$h = 30$	9.43	74.81	15.77	4.93	22.28
$k = 6$	8.77	74.81	16.41	4.75	21.98
$h = 5$	8.78	74.80	16.42	4.18	20.16
$h = 10$	8.77	74.81	16.43	4.45	21.02
$h = 15$	8.78	74.81	16.41	4.59	21.48
$h = 20$	8.77	74.80	16.44	4.66	21.70
$h = 25$	8.77	74.80	16.42	4.70	21.83
$h = 30$	8.78	74.81	16.41	4.72	21.89

III Risultati simulazioni di GreedyToStealth

Tabella 3: Confronto delle metriche principali per la strategia GREEDYTO-STEALTH al variare di k e h .

Configurazione	Successo (%)	Fallimento (%)	Rilevamento (%)	Passi Medi	Tempo Medio (ore)
$k = 1$	15.34	74.83	9.84	5.90	50.96
$h = 5$	15.34	74.78	9.88	5.47	26.36
$h = 10$	15.33	74.81	9.86	5.81	39.27
$h = 15$	15.34	74.80	9.86	5.97	46.77
$h = 20$	15.33	74.83	9.84	5.92	50.20
$h = 25$	15.32	74.86	9.82	5.91	51.09
$h = 30$	15.34	74.81	9.86	5.90	50.96
$k = 2$	14.91	74.81	10.28	5.69	51.98
$h = 5$	14.90	74.81	10.29	5.43	33.58
$h = 10$	14.90	74.80	10.30	5.69	44.11
$h = 15$	14.90	74.80	10.30	5.75	49.67
$h = 20$	14.91	74.79	10.30	5.70	51.59
$h = 25$	14.89	74.84	10.27	5.69	51.93
$h = 30$	14.89	74.82	10.28	5.69	51.98
$k = 3$	14.59	74.84	10.56	5.36	45.04
$h = 5$	14.59	74.81	10.60	5.27	34.50
$h = 10$	14.59	74.81	10.60	5.39	41.04
$h = 15$	14.60	74.81	10.59	5.38	44.04
$h = 20$	14.59	74.81	10.60	5.36	44.92
$h = 25$	14.60	74.81	10.58	5.35	45.00
$h = 30$	14.59	74.83	10.57	5.35	44.96
$k = 4$	14.45	74.83	10.72	5.16	34.38
$h = 5$	14.44	74.82	10.75	5.14	29.47
$h = 10$	14.47	74.79	10.74	5.18	32.78
$h = 15$	14.46	74.79	10.76	5.17	34.05
$h = 20$	14.45	74.84	10.71	5.16	34.41
$h = 25$	14.47	74.80	10.72	5.16	34.39
$h = 30$	14.45	74.83	10.72	5.16	34.42
$k = 5$	14.39	74.82	10.79	5.10	27.06
$h = 5$	14.39	74.81	10.79	5.09	24.97
$h = 10$	14.39	74.82	10.80	5.10	26.38
$h = 15$	14.40	74.80	10.80	5.10	26.96
$h = 20$	14.40	74.83	10.77	5.09	27.02
$h = 25$	14.41	74.82	10.77	5.09	27.06
$h = 30$	14.41	74.81	10.77	5.09	26.99
$k = 6$	14.39	74.82	10.80	5.08	23.40
$h = 5$	14.36	74.80	10.84	5.08	22.51
$h = 10$	14.38	74.81	10.81	5.09	23.14
$h = 15$	14.38	74.81	10.81	5.08	23.35
$h = 20$	14.38	74.81	10.82	5.08	23.37
$h = 25$	14.38	74.84	10.78	5.08	23.37
$h = 30$	14.36	74.84	10.80	5.08	23.36

IV Risultati simulazioni di StealthToMaxProb

Tabella 4: Confronto delle metriche principali per la strategia STEALTHTO-MAXPROBAB al variare di k e h .

Configurazione	Successo (%)	Fallimento (%)	Rilevamento (%)	Passi Medi	Tempo Medio (ore)
$k = 1$	15.60	74.81	9.59	5.48	20.40
$h = 5$	15.59	74.82	9.58	5.51	50.58
$h = 10$	15.58	74.83	9.59	5.36	42.00
$h = 15$	15.59	74.82	9.59	5.34	33.15
$h = 20$	15.58	74.81	9.61	5.34	27.22
$h = 25$	15.58	74.82	9.60	5.38	23.93
$h = 30$	15.61	74.82	9.58	5.41	22.12
$k = 2$	15.47	74.81	9.72	5.70	25.56
$h = 5$	15.47	74.84	9.69	5.61	47.73
$h = 10$	15.48	74.82	9.70	5.56	40.12
$h = 15$	15.48	74.82	9.70	5.57	33.71
$h = 20$	15.47	74.82	9.71	5.60	29.88
$h = 25$	15.47	74.81	9.72	5.63	27.71
$h = 30$	15.47	74.82	9.71	5.66	26.57
$k = 3$	15.41	74.81	9.78	5.87	34.39
$h = 5$	15.41	74.81	9.78	5.72	47.73
$h = 10$	15.41	74.82	9.77	5.73	42.68
$h = 15$	15.40	74.82	9.78	5.76	38.80
$h = 20$	15.40	74.82	9.78	5.80	36.62
$h = 25$	15.41	74.81	9.78	5.83	35.45
$h = 30$	15.42	74.79	9.79	5.85	34.87
$k = 4$	15.37	74.80	9.83	5.95	42.04
$h = 5$	15.36	74.83	9.81	5.83	48.66
$h = 10$	15.36	74.83	9.81	5.86	45.89
$h = 15$	15.37	74.82	9.81	5.88	44.01
$h = 20$	15.36	74.83	9.81	5.91	43.01
$h = 25$	15.36	74.80	9.84	5.92	42.48
$h = 30$	15.37	74.81	9.82	5.94	42.27
$k = 5$	15.36	74.80	9.84	5.95	46.15
$h = 5$	15.35	74.83	9.81	5.86	49.59
$h = 10$	15.34	74.82	9.84	5.89	48.05
$h = 15$	15.33	74.83	9.83	5.91	47.10
$h = 20$	15.35	74.82	9.84	5.93	46.57
$h = 25$	15.34	74.82	9.84	5.94	46.33
$h = 30$	15.34	74.82	9.83	5.95	46.21
$k = 6$	15.34	74.81	9.85	5.94	48.54
$h = 5$	15.34	74.84	9.82	5.90	50.17
$h = 10$	15.33	74.82	9.85	5.91	49.38
$h = 15$	15.34	74.83	9.83	5.92	48.91
$h = 20$	15.34	74.80	9.86	5.93	48.71
$h = 25$	15.34	74.80	9.86	5.94	48.64
$h = 30$	15.33	74.84	9.84	5.94	48.56

V Risultati simulazioni di MaxProbToGreedy

Tabella 5: Confronto delle metriche principali per la strategia MAXPROBABILITYTOGREEDY al variare di k e h .

Configurazione	Successo (%)	Fallimento (%)	Rilevamento (%)	Passi Medi	Tempo Medio (ore)
$k = 1$	14.36	74.81	10.83	5.08	20.24
$h = 5$	14.40	74.80	10.80	5.40	20.76
$h = 10$	14.36	74.81	10.83	5.24	20.49
$h = 15$	14.36	74.81	10.83	5.17	20.39
$h = 20$	14.37	74.80	10.83	5.12	20.30
$h = 25$	14.36	74.82	10.82	5.10	20.27
$h = 30$	14.35	74.80	10.85	5.09	20.25
$k = 2$	14.97	74.80	10.23	5.12	20.02
$h = 5$	14.98	74.80	10.21	5.34	20.37
$h = 10$	14.96	74.82	10.22	5.23	20.18
$h = 15$	14.97	74.80	10.23	5.18	20.12
$h = 20$	14.98	74.81	10.22	5.15	20.07
$h = 25$	14.97	74.79	10.24	5.14	20.05
$h = 30$	14.97	74.81	10.22	5.13	20.01
$k = 3$	15.33	74.80	9.87	5.27	20.13
$h = 5$	15.34	74.80	9.86	5.38	20.30
$h = 10$	15.32	74.80	9.87	5.33	20.22
$h = 15$	15.33	74.82	9.86	5.30	20.17
$h = 20$	15.32	74.82	9.86	5.28	20.14
$h = 25$	15.32	74.82	9.86	5.28	20.14
$h = 30$	15.33	74.80	9.86	5.28	20.14
$k = 4$	15.49	74.81	9.70	5.39	20.30
$h = 5$	15.49	74.81	9.70	5.43	20.34
$h = 10$	15.48	74.81	9.70	5.41	20.32
$h = 15$	15.50	74.79	9.71	5.40	20.30
$h = 20$	15.49	74.80	9.71	5.39	20.29
$h = 25$	15.48	74.82	9.70	5.39	20.27
$h = 30$	15.49	74.80	9.71	5.39	20.28
$k = 5$	15.54	74.82	9.64	5.44	20.35
$h = 5$	15.55	74.80	9.64	5.46	20.39
$h = 10$	15.55	74.81	9.64	5.45	20.36
$h = 15$	15.56	74.81	9.63	5.45	20.36
$h = 20$	15.57	74.80	9.63	5.44	20.36
$h = 25$	15.54	74.81	9.65	5.44	20.34
$h = 30$	15.57	74.79	9.64	5.44	20.35
$k = 6$	15.57	74.82	9.61	5.46	20.37
$h = 5$	15.58	74.81	9.61	5.47	20.40
$h = 10$	15.58	74.80	9.62	5.47	20.39
$h = 15$	15.57	74.80	9.62	5.47	20.40
$h = 20$	15.58	74.80	9.62	5.46	20.38
$h = 25$	15.58	74.81	9.61	5.47	20.39
$h = 30$	15.58	74.80	9.62	5.46	20.38

VI Risultati simulazioni di SimualtedAnnealing

Tabella 6: Confronto delle metriche delle migliori configurazioni SIMULATEDANNEALING.

Configurazione	Successo (%)	Fallimento (%)	Rilevamento (%)	Passi Medi	Tempo Medio (ore)
Top1	15.59	74.79	9.62	5.48	20.48
Top2	15.61	74.78	9.61	5.48	20.40
Top3	15.57	74.81	9.62	5.44	34.98
Top4	15.56	74.81	9.63	5.45	31.73
Top5	15.59	74.79	9.62	5.47	20.39
Top1_Variant_sigmoid	15.56	74.81	9.63	5.48	20.83
Top1_Variant_exponential	15.61	74.77	9.62	5.48	21.13

VII Risultati simulazioni di StochasticMax-Prob

Tabella 7: Confronto delle metriche della strategia STOCHASTICMAXPROB.

Configurazione	Successo (%)	Fallimento (%)	Rilevamento (%)	Passi Medi	Tempo Medio (ore)
$p = 0.005$	15.57	74.86	9.58	5.48	20.77
$p = 0.010$	15.55	74.88	9.58	5.48	21.14
$p = 0.015$	15.56	74.86	9.57	5.49	21.54
$p = 0.020$	15.55	74.86	9.58	5.49	21.93
$p = 0.025$	15.55	74.87	9.58	5.49	22.29
$p = 0.030$	15.56	74.86	9.58	5.49	22.65
$p = 0.040$	15.56	74.85	9.59	5.49	23.44
$p = 0.050$	15.56	74.87	9.58	5.50	24.22
$p = 0.070$	15.56	74.87	9.57	5.50	25.76
$p = 0.100$	15.56	74.86	9.58	5.51	28.06

Bibliografia

- [1] F. Baiardi e V. Sammartino. “Simulation-Powered Cybersecurity: Real-Time Risk Assessment via Non-Intrusive Security Twin”. In: *The Journal of Supercomputing — Special Issue* (2026).
- [2] Genevieve Bartlett, John Heidemann e Christos Papadopoulos. “Understanding passive and active service discovery”. In: *Proceedings of the 7th ACM SIGCOMM Conference on Internet Measurement*. IMC '07. San Diego, California, USA: Association for Computing Machinery, 2007, pp. 57–70. ISBN: 9781595939081. DOI: 10.1145/1298306.1298314.
- [3] runZero. *Active Scanning Industrial Control Systems Safely*. 2024.
- [4] Gene Bartlett e John Heidemann. “Understanding Passive and Active Service Discovery”. In: *Proceedings of the 7th ACM SIGCOMM*. 2007, pp. 1–14.
- [5] F. Baiardi, V. Sammartino e S. Ruggieri. “NotLine: A Non-Intrusive Automated Platform to Build a Digital Twin”. In: *2025 29th International Symposium on Distributed Simulation and Real Time Applications (DS-RT)*. 2025, pp. 1–8. DOI: 10.1109/DS-RT68115.2025.11185873.
- [6] L. Deri e S. Suin. “Effective traffic measurement using ntop”. In: *IEEE Communications Magazine* 38.5 (2000), pp. 138–143. DOI: 10.1109/35.841838.
- [7] F. Baiardi, V. Sammartino e S. Ruggieri. “Graph-Based Cyber Defence using a Security Twin”. In: *29th International Symposium on Distributed Simulation and Real Time Applications (DS-RT 2025)*. 2025.
- [8] Quanyan Li et al. “Monte Carlo-based threat assessment of power system security”. In: *2020 PMAPS*. IEEE. 2020, pp. 1–6.
- [9] F. Baiardi, V. Sammartino e S. Ruggieri. “Evaluating Adversary Strategies Through a Security Twin”. In: *IEEE International Conference on Pervasive Computing and Communications (PerCom Workshops 2026)*. 2026.
- [10] Scott Kirkpatrick, C Daniel Gelatt e Mario P Vecchi. “Optimization by simulated annealing”. In: *Science* 220.4598 (1983), pp. 671–680.

- [11] Takuya Akiba et al. “Optuna: A Next-generation Hyperparameter Optimization Framework”. In: *Proceedings of the 25th ACM SIGKDD International Conference on Knowledge Discovery & Data Mining*. KDD ’19. Anchorage, AK, USA: Association for Computing Machinery, 2019, pp. 2623–2631. ISBN: 9781450362016. DOI: 10.1145/3292500.3330701.